DEGREE PROJECT

Automating Active and Passive Web Reconnaissance for Improved External Attack Surface Visibility

Waqas ur Rehman

Information Security, master's level (120 credits)
2026

Luleå University of Technology
Department of Computer Science, Electrical and Space Engineering

LULEÅ UNIVERSITY OF TECHNOLOGY

[This page intentionally left blank]

Abstract

External web reconnaissance is an important activity for understanding an organization's externally visible attack surface. However, the reconnaissance is often performed using separate tools for subdomain discovery, DNS validation, HTTP probing, port scanning, and reporting. This can create a fragmented workflow and require a additional manual effort to combine, validate, and organize the results.

This thesis presents the design, implementation and evaluation of the External Web Reconnaissance System (EWRS) an integrated reconnaissance framework developed using a Design Science Research approach. The EWRS framework combines passive and active reconnaissance activities within one structured workflow, while a software prototype implements the framework through a graphical user interface. The prototype integrates Subfinder and Amass for passive discovery, DNS validation, httpx for HTTP/HTTPS probing, Nmap for port and service discovery, result deduplication, exposure analysis and structured reporting and also the EWRS provides Passive, Active, and Hybrid scan modes to support different reconnaissance purposes.

The prototype was evaluated using selected target domains and was also compared with the manual use of individual reconnaissance tools. The evaluation showed that EWRS can combine candidate discovery, DNS validation, live web service identification, port scanning, exposure prioritization and reporting within one workflow. Hybrid Mode provided the most complete reconnaissance process because it combined passive discovery with active validation. The tool comparisons also showed that EWRS preserves the capabilities of the integrated tools while reducing the need for manual result processing and producing more structured output.

The main contribution of this thesis is therefore an integrated reconnaissance framework and its implemented prototype for supporting external attack surface visibility through automation, validation, result organization, exposure prioritization and reporting. The EWRS is intended as a research prototype and support tool for authorized external reconnaissance rather than a complete vulnerability assessment platform.

Keywords: External Web Reconnaissance, External Attack Surface, EWRS, Design Science Research, Passive Reconnaissance, Active Reconnaissance, Asset Discovery, Exposure Analysis

Abstract....2
Chapter 1....6
Introduction....6
1.1 Overview....6
1.2 Terminology Used in This Thesis....7
1.3 Reconnaissance....7
1.3.1 Active Reconnaissance....7
1.3.2 Passive Reconnaissance....8
1.4 Problem Statement....8
1.5 Research Questions....8
1.6 Research Objectives....9
1.7 Significance of Work and Potential Benefit....9
1.8 Novel Contribution....10
1.9 Summary....11
Chapter 2....12
Literature Review And Related Work....12
2.1 External Attack Surface Management....12
2.2 Web Reconnaissance Techniques....12
2.3 Passive Reconnaissance....13
2.3.1 OSINT and Public Sources....13
2.3.2 Certificate Transparency Logs....13
2.3.3 Limitations of Passive Reconnaissance....14
2.4 Active Reconnaissance....14
2.4.1 DNS Resolution and Active Checking....14
2.4.2 HTTP Probing and Live Web Service Validation....14
2.4.3 Port Scanning and Service Discovery....15
2.4.4 Limitations and Ethical Use of Active Reconnaissance....15
2.5 Existing Reconnaissance Tools....15
2.5.1 Subfinder....15
2.5.2 Amass....16
2.5.3 httpx....16
2.5.4 Nmap....16
2.6 Limitations of Existing Reconnaissance Approaches....16
2.7 Summary....17
Chapter 3....18
Research Methodology....18
3.1 Introduction....18

3.2 Research Approach: Design Science Research....19
3.3 Design Science Research Process....19
3.4 Application of DSR in EWRS....21
3.5 Data Collection and Testing Approach....23
3.6 Scan Modes Used in EWRS....24
3.6.1 Passive Mode....25
3.6.2 Active Mode....26
3.6.3 Hybrid Mode....28
3.7 Evaluation Criteria....31
3.8 Ethical Considerations....31
3.9 Summary....32
Chapter 4....33
Proposed EWRS Framework....33
4.1 Introduction....33
4.2 Overview of the Proposed EWRS Framework....34
4.3 EWRS Architecture....35
4.4 EWRS Workflow....36
4.5 EWRS Modules....36
4.5.1 Target Input and Validation Module....37
4.5.2 Passive Discovery Module....37
4.5.3 DNS Resolution and Active Validation Module....38
4.5.4 HTTP Probe Module....38
4.5.5 Port Scan Module....39
4.5.6 Exposure Analysis and Scoring Module....39
4.5.7 Reporting and Export Module....41
4.6 Public Metadata and Scope Limitation....42
4.7 Summary....43
Chapter 5....44
Design and Implementation....44
5.1 Introduction....44
5.2 Tools and Technologies....44
5.2.1 Programming Language....45
5.2.2 Graphical User Interface Library....45
5.2.3 External Reconnaissance Tools....45
5.2.4 Output and Export Formats....45
5.3 GUI Design and User Interface....46
5.4 Backend Implementation....47
5.5 Tool Integration....48

5.5.1 Subfinder Integration..... 48
5.5.2 Amass Integration..... 49
5.5.3 httpx Integration..... 49
5.5.4 Nmap Integration..... 49
5.6 Result Processing and Export..... 49
5.7 Implementation Challenges..... 50
5.8 Summary..... 51
Chapter 6..... 52
Evaluation and Results..... 52
6.1 Introduction..... 52
6.2 Evaluation Setup..... 53
6.3 Test Targets and Scan Configuration..... 53
6.4 Evaluation Results..... 54
6.4.1 Passive Mode Results..... 55
6.4.2 Active Mode Results..... 57
6.4.3 Hybrid Mode Results..... 59
6.5 Exposure Scoring Results..... 61
6.6 Manual Tool and EWRS Workflow Comparison 62
6.6.1 Subfinder: Manual PowerShell Result vs EWRS Result 63
6.6.2 Amass: Manual PowerShell Result vs EWRS Result..... 66
6.6.3 httpx: Manual PowerShell Result vs EWRS Result..... 69
6.6.4 Nmap: Manual PowerShell Result vs EWRS Result..... 72
6.6.5 Full Workflow Comparison..... 76
6.7 Mapping Findings to Research Questions..... 79
6.8 Summary..... 81
Chapter 7..... 82
Discussion..... 82
7.1 Introduction..... 82
7.2 Discussion of Evaluation Findings..... 82
7.3 Contribution to Knowledge and Practice..... 84
7.4 Limitations of EWRS..... 85
7.5 Ethical and Scope Discussion..... 87
7.6 Future Improvements..... 88
7.7 Summary..... 89
Chapter 8..... 90
Conclusion..... 90
References:..... 93

Chapter 1

Introduction

1.1 Overview

The use of web applications, cloud services, APIs and online platforms has increased a very quickly in the modern organizations and these technologies help organizations to work faster and provide a better services but if we see they also increase the number of systems that are visible on the public internet and every public facing domain, subdomain, IP address, web service, cloud resource and exposed endpoint can become a part of an organization external attack surface.

An external attack surface includes all internet facing assets that may be seen or reached by an attacker so if these assets are not properly monitored and they can create a security risks such as exposed services, weak configurations, forgotten subdomains, outdated systems or cloud misconfigurations and because organizations are now using more cloud platforms and third party services as well as the web applications it is becoming a harder for security teams to know exactly what is exposed online [1,2].

External Attack Surface Management also called EASM, is a proactive security approach that focuses on discovering, monitoring and reducing the risks across the external facing assets. EASM uses techniques such as reconnaissance, vulnerability scanning, threat intelligence and automated monitoring to help organizations understand their external exposure before attackers can misuse it [1].

Web reconnaissance plays an important role in this process. Reconnaissance helps security professionals collect information about a target digital presence and this may include domains, subdomains, IP addresses, open services , web technologies, certificates and other public information so without a proper reconnaissance it is difficult to understand the full attack surface of an organization.

However many reconnaissance activities are still performed manually using separate tools and a tester may use one tool for subdomain discovery and another tool for DNS information, another tool for HTTP probing, and another for port scanning so after that the tester must manually

combine the results, remove duplicate entries, check which assets are live and prepare a report so this process takes time and can lead to missed assets or inconsistent results.

This thesis focuses on the design, implementation and evaluation of an External Web Reconnaissance System called EWRS and the proposed EWRS framework combines passive and active reconnaissance activities in one structured workflow. A software prototype was developed to implement the framework and evaluate how it supports asset discovery, validation, result organization and reporting.

1.2 Terminology Used in This Thesis

In this thesis, the term EWRS refers to the External Web Reconnaissance System developed as part of this research and when EWRS is used alone it refers generally to the overall proposed solution. To keep the terminology clear and consistent, several related terms are used with specific meanings.

The EWRS framework refers to the overall design that combines passive discovery, active validation, result processing, exposure analysis and reporting into one structured approach. The EWRS prototype refers to the software implementation developed in Python to demonstrate and evaluate the proposed framework and the EWRS workflow refers to the sequence of activities performed within the prototype, including target validation, asset discovery, deduplication, DNS validation, HTTP probing, port scanning, exposure analysis and reporting. In the context of Design Science Research, the EWRS framework and its implemented prototype are treated as the research artifact developed and evaluated in this study.

In the EWRS interface and generated reports, the label “HTTP Live Hosts” is used for assets that respond over HTTP or HTTPS and in the thesis text, these results are referred to as live web services.

1.3 Reconnaissance

So what is reconnaissance the reconnaissance is a process of collecting information about a target before performing deeper security testing and in cybersecurity the reconnaissance is used to gather information about target networks, systems, applications and services that may later be used to identify weaknesses or plan further security testing [3]. In web application security the reconnaissance helps to identify what systems and services are available and how they are connected and which technologies are being used.

1.3.1 Active Reconnaissance

Active reconnaissance involves direct interaction with the target system. And in this type of reconnaissance the tester sends requests to the target in order to collect more accurate information. Examples include DNS resolution, HTTP probing, port scanning, service detection, banner grabbing and checking whether discovered hosts are live [3]. Active reconnaissance is useful because it can confirm whether an asset actually exists and is reachable but it must be performed carefully because it may be detected by logs, firewalls or intrusion detection systems.

1.3.2 Passive Reconnaissance

Passive reconnaissance collects information without directly interacting with the target system. Instead, it uses public sources and third party datasets such as WHOIS records, DNS lookup services, search engines, website footprinting, OSINT sources and Certificate Transparency logs [3].So the passive reconnaissance is useful because it can reveal external information with a lower chance of detection but the results may include outdated or inactive assets. Therefore passive discovery should be combined with active validation to produce more reliable results.

1.4 Problem Statement

External web reconnaissance requires information to be collected through several different techniques and sources and the previous research shows that reconnaissance may include passive and active methods for collecting information about domains, hosts, network services, applications and other externally visible technical information[3]. External Attack Surface Management also depends on several activities, including reconnaissance, asset discovery, OSINT, subdomain discovery, port scanning and the use of automated tools to improve visibility of internet facing assets[1].

The practical problem addressed in this thesis is that these reconnaissance activities are often handled as separate steps and may produce different types of output that must be validated, organized and combined before they provide a clear view of the external attack surface and this can increase manual effort and make the reconnaissance workflow more difficult to manage consistently.

Therefore, the purpose of this thesis is to design and implement and evaluate the External Web Reconnaissance System (EWRS) which combines passive discovery, active validation, result processing, exposure prioritization and reporting within one structured workflow.

1.5 Research Questions

There are a few main research question of this thesis is

How can an automated framework that combines the active and passive web reconnaissance improve external attack surface visibility compared to using separate tools manually?

The following sub research questions support the main research question

SRQ1: What are the biggest problems with current reconnaissance tools and methods that make reconnaissance incomplete or unreliable (DNS, subdomains, directories etc.)?

SRQ2: How much more verified information (unique live assets) can we find when we combine passive sources like CT logs with active probing and enumeration?

SRQ3: How much does automation reduce manual work and improve consistency (less duplication, clearer results) compared to running tools one-by-one?

1.6 Research Objectives

The main objective of this thesis is to design and develop and evaluate an automated External Web Reconnaissance System that combines the active and passive reconnaissance methods.

The are some specific objectives are:

1. To study existing active and passive reconnaissance techniques used for discovering external web assets.
2. To identify the limitation of the current reconnaissance tools and manual workflows.
3. To design a modular EWRS workflow that combines the passive discovery, active validation, and result organization.
4. To implement a prototype that can collect domains and subdomains, validate discovered assets, identify live web services, remove duplicate results and present findings clearly.
5. To evaluate the prototype using selected target domains and compare the results with manual or separate tool based reconnaissance.
6. To produce a clear report/output that can support the security practitioners in understanding external exposure.

1.7 Significance of Work and Potential Benefit

This research is significant because the external attack surface visibility is an important part of modern cybersecurity and if the organization does not know that which assets are exposed to the internet it cannot properly protect them so unknown or forgotten assets can become easy targets for attackers and continuous visibility is therefore important because organizations cannot effectively reduce exposure if they do not know which domains, subdomains, services, and cloud resources are publicly reachable[1]

The purpose of the EWRS framework can help security practitioners, students and ethical hackers by reducing manual work during reconnaissance and instead of running different tools separately and manually combining results the EWRS aims to provide a single workflow for collecting, validating and organizing reconnaissance data.

EWRS can also help to improve the quality of the reconnaissance results and by combining the passive discovery with active validation and the EWRS can reduce the outdated or inactive results and focus more on assets that are actually live and this can make the final output more useful for further security testing.

Another benefit is reporting so clear reporting helps users to understand what was discovered and what need further attention and this is useful not only for technical testers but also for the security teams that need to prioritize follow up actions.

1.8 Novel Contribution

The main contribution of this thesis is the design and development of a modular automated reconnaissance framework for improving external attack surface visibility and the proposed of EWRS framework contributes in the following ways:

- It combines passive and active reconnaissance methods in one workflow.
- It supports external asset discovery, including domains, subdomains, IP addresses, and live web services.
- It includes validation steps to check which discovered assets are reachable.
- It reduces duplicate and unorganized results by cleaning and structuring the output.
- It provides a best GUI based approach that makes the reconnaissance process easier to manage.
- It produces clearer output that can support further analysis and reporting.

The novelty of this work is not that it creates every reconnaissance technique from zero and instead the contribution is in integrating useful reconnaissance steps into one structured and automated workflow and this makes the process more easier, faster and more consistent for security testing and external visibility.

1.9 Summary

This chapter introduced the background and motivation of the thesis and its also explained that modern organizations have many internet facing assets which increases their external attack surface. It also explained the importance of web reconnaissance and the difference between active and passive reconnaissance.

The chapter presented the main problem like the existing reconnaissance tools are useful but often fragmented, requiring manual work to combine, validate and report results. So to address this problem the thesis proposes EWRS an automated External Web Reconnaissance System that combines passive discovery and active validation in one modular workflow.

The chapter also presented the research questions, objectives, significance and novel contribution of the study and the next chapter will review existing literature and related work on external attack surface management, DNS enumeration, subdomain discovery, Certificate Transparency, OSINT, and reconnaissance automation.

Chapter 2

Literature Review And Related Work

2.1 External Attack Surface Management

Modern organizations use many internet facing systems such as websites, web applications, APIs, cloud services and third party platforms so these systems improve the digital services but they can also increase the number of assets exposed to the public internet and these exposed assets form the external attack surface which may include domains, subdomains, IP addresses, open ports, web services, certificates, and cloud resources.

External Attack Surface Management, or EASM is used to discover, monitor and manage these exposed assets so the main purpose is to help the organizations to understand what is visible from an attacker's point of view and if an organization does not know which assets are exposed it becomes difficult to protect them so unknown assets, forgotten subdomains and shadow IT can increase security risks because attackers may find them before the organization does[1,2].

EASM uses reconnaissance, asset discovery, vulnerability scanning, threat intelligence and reporting to identify and prioritize weaknesses across the digital assets[1]. Cyber asset visibility is also important because organizations need to know what assets they have where they are located and how they are connected before they can defend them properly[2].

In this thesis, the EASM is connected to the proposed EWRS framework and EWRS aims to improve external attack surface visibility by combining passive reconnaissance and active validation in one automated workflow so this helps make the reconnaissance process more structured, faster, and easier to manage.

2.2 Web Reconnaissance Techniques

Web reconnaissance is the process of collecting the information about a target's external digital presence before deeper security testing so it helps identify the domains, subdomains, IP addresses, services, technologies, and other visible assets.

Reconnaissance can be active or passive so Active reconnaissance directly interacts with the target through scanning, probing, or service checking and while the Passive reconnaissance

collects information from public or third party sources without directly contacting the target system. Reconnaissance techniques can include OSINT collection, DNS lookup, WHOIS lookup, website footprinting, subdomain discovery, HTTP probing, and port scanning[1,3,11].

In this thesis,the web reconnaissance is important because EWRS combines several reconnaissance steps into one automated workflow and this helps collect, validate, clean, and report external assets in a more structured way.

2.3 Passive Reconnaissance

Passive reconnaissance is the process of collecting information from public or third party sources without directly interacting with the target system and it can use sources such as search engines, WHOIS records, DNS lookup services, OSINT platforms, public archives, passive DNS data, and Certificate Transparency logs.

Passive reconnaissance is useful because it can reveal domains, subdomains, IP addresses, technologies and other external information with a lower chance of detection so however the passive results may also include outdated or inactive assets, so they should be validated before being used in security testing [3,4,5].

In EWRS, passive reconnaissance is used as the first discovery stage and it helps to collect possible external assets, which can later be checked through active validation.

2.3.1 OSINT and Public Sources

Open Source Intelligence, or OSINT, means that collecting the information from publicly available sources. In EWRS, OSINT is used as part of the initial discovery process to identify possible external assets such as domains, subdomains, IP addresses, and related public records and these results help create the first asset list before validation is performed[1,3].

2.3.2 Certificate Transparency Logs

Certificate Transparency logs are public records of issued SSL/TLS certificates and these logs are useful in passive reconnaissance because certificates often contain domain and subdomain names and previous research shows that CT logs can reveal previously unknown domains and services so in EWRS, this type of information supports passive subdomain discovery before active checking is performed [4,5].

2.3.3 Limitations of Passive Reconnaissance

Although passive reconnaissance is useful it has some limitations. Public sources and certificate logs may contain old, duplicate, or inactive records. For example, a subdomain may appear in a public source but may no longer resolve or host a live web service so therefore, passive results should not be treated as final results. In EWRS, passive discovery is followed by active validation to confirm which assets are actually reachable[3,4].

2.4 Active Reconnaissance

Active reconnaissance is the process of collecting information by directly interacting with the target system. In external web reconnaissance this can include DNS resolution, HTTP probing, service checking and port scanning. These techniques can help to confirm whether discovered domains, subdomains, IP addresses, and web services are actually live and reachable.

Active reconnaissance is useful because passive sources may contain old or inactive results and by sending controlled requests, security testers can validate the assets discovered during passive reconnaissance. Active DNS research also shows that systematic DNS querying can help collect domain and IP related information for security analysis[1,3,6].

However, the active reconnaissance should be performed carefully because it creates traffic that may be detected by logs, firewalls or intrusion detection systems[3]. In EWRS active reconnaissance is mainly used for validation so after passive discovery it creates an initial asset list, active checks help confirm which assets are reachable and useful for further analysis.

2.4.1 DNS Resolution and Active Checking

DNS resolution is used to check whether discovered domains or subdomains resolve to valid IP addresses and this helps separate valid assets from records that may be old or inactive and In EWRS, DNS checking is used as one of the validation steps after passive discovery[3,6]

2.4.2 HTTP Probing and Live Web Service Validation

HTTP probing is used to check whether discovered assets expose active web services over HTTP or HTTPS so this step helps to identify assets expose live web services and useful for further analysis. In EWRS, HTTP probing supports live web service validation after domains and subdomains are collected[7].

2.4.3 Port Scanning and Service Discovery

Port scanning is used to identify open ports and reachable services on a target system and it can help security testers understand which services are exposed from the outside[1,3] and in EWRS, port scanning is included as an active module to support external service discovery.

2.4.4 Limitations and Ethical Use of Active Reconnaissance

Active reconnaissance should be performed carefully because it creates traffic that may be detected by logs, firewalls or intrusion detection systems[3]. Because of this the active scanning should only be performed in a controlled way and on authorized or suitable targets. In EWRS, active reconnaissance is mainly used for validation not aggressive exploitation.

2.5 Existing Reconnaissance Tools

EWRS does not build every reconnaissance function from the beginning instead of this it's integrates the existing reconnaissance tools that are already used for specific tasks and this approach is suitable for this thesis because the main focus is not to create new scanners but to combine useful tools into one automated and structured workflow and this research on EASM and reconnaissance shows that external asset discovery often depends on different techniques and sources such as passive and active reconnaissance, OSINT, subdomain discovery, DNS-related checks, scanning, and reporting[1,3].

Using existing tools also makes the framework more practical and each tool perform a different role in the reconnaissance process so for example the one tool may be better for subdomain discovery and another may be useful for HTTP probing, and another may support port scanning. EWRS connects these separate functions so that the user does not need to run each tool manually and combine the results by hand.

2.5.1 Subfinder

Subfinder is used for passive subdomain discovery and it collects the subdomains for a target domain from passive online sources[8]. the EWRS the Subfinder is used during the passive reconnaissance stage to collect the possible subdomains before the further validation is performed.

This is useful because subdomains often the host is important services such as web applications, APIs, admin panels, development environments or testing systems and some of these assets may be forgotten or not properly monitored by the organization[9].So by using the Subfinder the EWRS can create an initial list of discovered subdomains that can later be checked through DNS resolution and HTTP probing.

2.5.2 Amass

OWASP Amass is used for external asset discovery and attack surface mapping. It helps collect information about domains, subdomains, DNS records, and related external infrastructure[10]. In EWRS, Amass supports the discovery phase by adding another source of reconnaissance data.

Amass is useful because it provides a way to run a wide set of reconnaissance and enumeration tools, which can help security testers understand what information may be visible about an organization[10]. In EWRS, Amass output can be combined with other discovered results, cleaned, and prepared for validation.

2.5.3 httpx

Httpx is used for HTTP probing and live web service validation and after EWRS discovers domains or subdomains, the httpx helps check whether those assets expose active web services over HTTP or HTTPS and this step is important because passive discovery may return assets that are old, inactive, or no longer reachable [11]. In EWRS the httpx helps confirm which discovered assets expose live web services and can collect useful HTTP response information such as status codes, page titles, and other metadata .

2.5.4 Nmap

Nmap is used for port scanning and service discovery. It helps identify open ports and services running on reachable hosts[12]. In EWRS, Nmap is part of the active reconnaissance stage and supports the process of understanding which services are exposed on a target.

Port scanning is important because open services can increase the external attack surface. For example, a host may expose web services, mail services, SSH, FTP, or other network services. By using Nmap, EWRS can provide more technical information about reachable assets and support further analysis of exposed services.

2.6 Limitations of Existing Reconnaissance Approaches

Existing reconnaissance tools are useful but many of them focus on specific tasks like for example the one tool may focus on subdomain discovery and the another tool may check live

web services and another may perform port scanning and because of this the security testers often need to use several techniques or tools to get a more complete view of the external attack surface[1,3].

This creates a fragmented workflow and the user may need to collect results from different tools and remove duplicate entries and check which assets are live and organize the output manually and the subdomain enumeration research also shows that information may come from multiple sources and that candidate subdomains often need validation before they can be treated as reliable results [9].

Another limitation is that passive reconnaissance results are not always final and the public sources may include old or inactive records and while active scanning is needed to confirm which assets are actually reachable so therefore a useful reconnaissance workflow should combine passive discovery with active validation [3,9].

These limitations show the need for a structured and automated framework and the EWRS addresses this gap by combining the passive discovery, active validation, duplicate removal, and reporting into one workflow and this helps to make a reconnaissance easier, faster, and more consistent.

2.7 Summary

This chapter reviewed the main concepts and related work connected to EWRS and it discussed External Attack Surface Management, web reconnaissance, passive reconnaissance, active reconnaissance and the tools is used in the proposed framework and the review showed that external asset discovery depends on different techniques such as OSINT, subdomain discovery, DNS checks, HTTP probing, and port scanning.

The chapter also explained that existing reconnaissance tools are useful but they often focus on separate tasks and this can create a fragmented workflow where users must manually run different tools, combine results, remove duplicates, validate live web services and prepare reports. These limitations support the need for an automated framework such as EWRS which combines passive discovery, active validation, result cleaning and reporting into one structured workflow.

The next chapter presents the research methodology used in this thesis and explains how Design Science Research is applied to design, develop and evaluate the EWRS framework.

Chapter 3

Research Methodology

3.1 Introduction

This chapter explains the research methodology used in this thesis and the purpose of the thesis is to design, develop and evaluate an automated External Web Reconnaissance System called EWRS since the thesis focuses on building a practical framework to address a real problem in external web reconnaissance the study follows a Design Science Research approach [13,14].

Design Science Research is suitable for this thesis because it focuses on designing and evaluating artifacts that address identified practical problems. In this study the EWRS framework represents the proposed design while the software prototype serves as an implementation used to demonstrate and evaluate that design. This is consistent with Design Science Research where artifacts may be represented through models, methods, and implemented instantiations [13]. The practical problem addressed by EWRS is the fragmented nature of external web reconnaissance where separate tools are often required for passive discovery, active validation, port scanning and reporting.The conceptual foundation of EWRS is based on two connected areas of previous research. External Attack Surface Management provides the security context by emphasizing visibility of internet facing assets [1], and while reconnaissance research explains the role of passive and active information gathering techniques and the different types of technical information they can reveal [3]. Design Science Research then provides the research process used to transform these concepts into an artifact that can be designed, demonstrated and evaluated [13,14].

The methodology is used to guide the development of EWRS from problem identification to evaluation so first, the problem of fragmented reconnaissance is identified and then, the objectives of the solution are defined and after that, the EWRS framework is designed and implemented as a software prototype. The prototype is then demonstrated and evaluated using selected target domains and measurable criteria. This follows the Design Science Research Process, which includes problem identification, objectives of a solution, design and development, demonstration, evaluation, and communication [14].

This chapter also explains how data and results are collected during testing and the evaluation focuses on how EWRS supports asset discovery, live web service validation, duplicate reduction and reporting so the ethical considerations are also included because active reconnaissance may

interact with external systems and must therefore be performed carefully and within a controlled scope.

3.2 Research Approach: Design Science Research

This thesis uses Design Science Research as the main research approach.The Design Science Research is suitable when the purpose of a study is to design and evaluate an artifact that solves a practical problem and the artifact can be a framework, model, method, process or software system so Hevner et al explain that the Design Science Research focuses on creating useful artifacts and evaluating how well they address an identified problem[13].

DSR was selected for this thesis because the aim is not only to study existing reconnaissance tools but also to design an integrated framework and implement it as a working prototype that improves the reconnaissance workflow and the problem addressed in this thesis is that external web reconnaissance often requires several separate tools for passive discovery, active validation, port scanning, result cleaning and reporting so this creates a fragmented process the EWRS is designed as an artifact to address this problem by combining these steps into one automated workflow.

Another reason for selecting DSR is that it supports both development and evaluation and in this thesis the EWRS is not only described as an idea It is designed, implemented, demonstrated and evaluated using selected target domains and this makes DSR more suitable than a purely theoretical or survey-based method because the research contribution depends on the practical evaluation of the implemented prototype and the usefulness of the proposed framework.

The Design Science Research Process by Peffers et al also fits this thesis because it provides clear steps for conducting artifact-based research and these steps include problem identification, objectives of a solution, design and development, demonstration, evaluation, and communication[14] so these steps guide the EWRS project from identifying the research problem to building and evaluating the final prototype.

3.3 Design Science Research Process

The Design Science Research Process provides a structured way to conduct artifact-based research if we see the Peffers et al describe this process as a sequence of activities that guide the

researcher from identifying a problem to communicating the final results and the process includes six main steps first the problem identification and motivation, objectives of a solution, design and development, demonstration, evaluation and communication [14].

In this thesis, these steps are used to guide the development of EWRS. First the problem of fragmented external web reconnaissance is identified and then the objectives of EWRS are defined, such as combining passive discovery, active validation, duplicate removal, and reporting into one workflow and after that the EWRS framework is first designed, after which a working software prototype is developed to implement the proposed design.

The prototype is then demonstrated using selected target domains. and the results are evaluated based on criteria such as discovered assets, live web services, duplicate reduction, execution time and report clarity and so finally the research is communicated through the thesis by explaining the design, implementation, evaluation, findings, and limitations of EWRS.

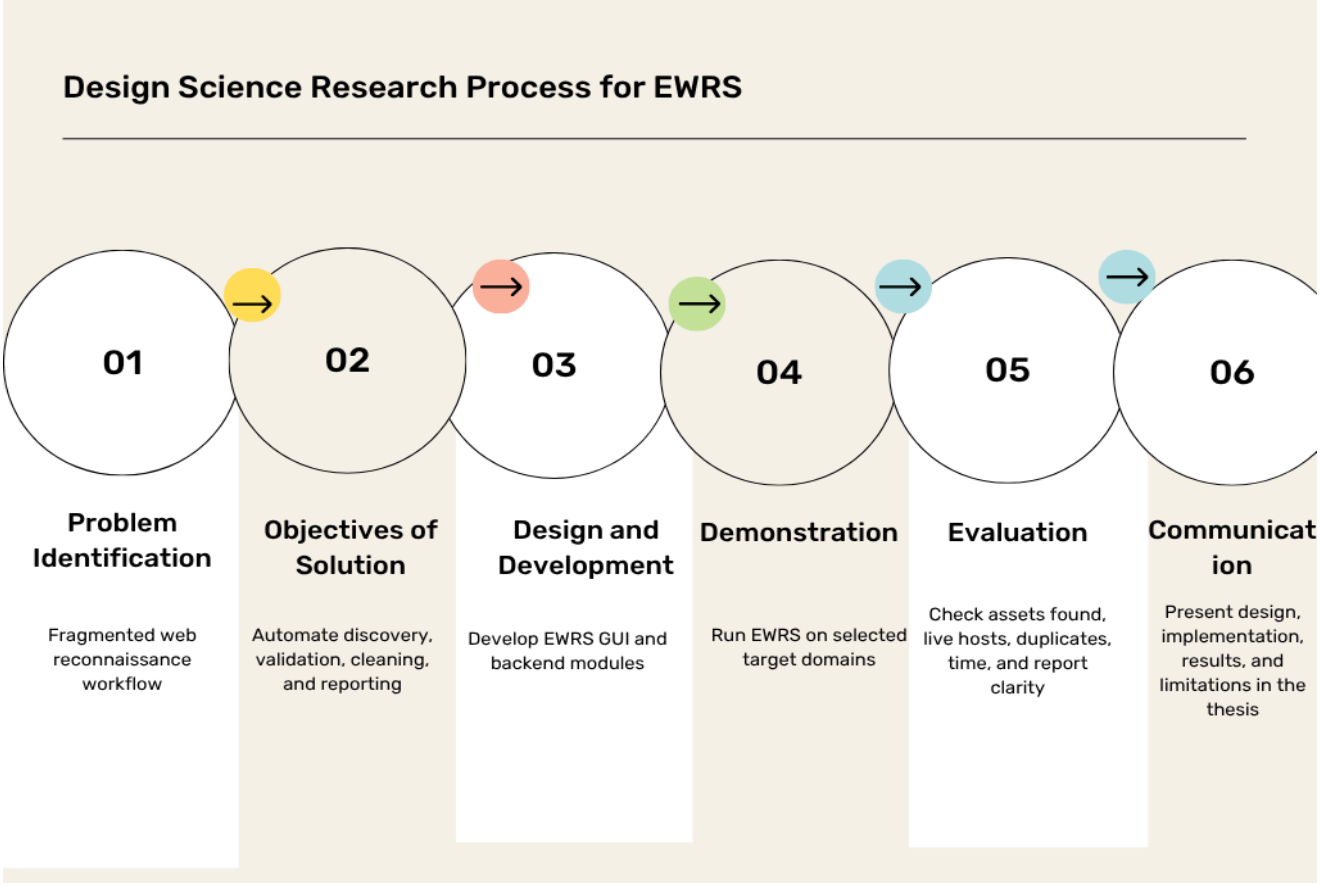


Figure 3.1 design science Research process applied to the EWRS thesis

3.4 Application of DSR in EWRS

In this thesis the Design Science Research Process is applied to guide the development and evaluation of EWRS so the first step is problem identification and the problem is identified in this research is that external web reconnaissance often requires several separate techniques or tools so the security testers may need to use separate techniques or tools for subdomain discovery, DNS checking, HTTP probing, port scanning, and reporting so the previous research shows that reconnaissance includes many different techniques and sources, such as passive reconnaissance, active scanning, DNS interrogation, and external asset discovery[1,3].

The second step is defining the objectives of the solution and the main objective of EWRS is to combine passive and active reconnaissance into one structured workflow so the framework is designed to collect possible external assets, validate discovered assets, remove duplicate results and present the output in a clear format so this follows the DSR idea of creating an artifact that addresses a practical problem[13,14].

The third step is design and development and in this step, the EWRS framework is implemented as a software prototype with a graphical user interface and backend modules and the prototype includes modules for passive discovery, DNS checks, HTTP probing, port scanning, result cleaning and report generation so in DSR the design. The development step focuses on building the artifact that will be demonstrated and evaluated[14].

The fourth step is demonstration and the EWRS is demonstrated by running the prototype on selected target domains and the demonstration shows how the prototype collects data, validates assets and presents results through the interface and exported reports so the demonstration is an important DSR activity because it shows how the artifact can be used to solve the identified problem[14].

The fifth step is evaluation and the prototype is evaluated using practical criteria such as number of discovered assets, number of live web services, duplicate reduction, execution time, and clarity of output and the evaluation is important in DSR because the artifact should be assessed to understand how well it addresses the problem it was designed for [13,14].

The final step is communication so the results of the design, implementation, testing, evaluation, and limitations are communicated through this thesis and this allows the research process and the developed artifact to be reviewed and understood and communication is also part of the Design Science Research Process because the artifact and its results should be presented to relevant audiences[14].

The DSR process is also connected directly to the research methods used in this study and the demonstration step is carried out through practical testing of the EWRS prototype using selected

target domains and scan configurations. The evaluation step is carried out by collecting and reviewing the results produced during these tests using the evaluation criteria defined in Section 3.7. The data collection and testing approach described in Section 3.5 therefore supports the demonstration and evaluation activities of the DSR process.

Table 3.1: Alignment of the DSR Process with the EWRS Study

DSR step	Application in this thesis	Thesis section
1. Problem identification and motivation	Fragmented external web reconnaissance requires separate tools and manual result processing.	Sections 1.4, 2.6, 3.4
2. Objectives of a solution	Define the objectives for integrating passive discovery, active validation, result organization and reporting.	Sections 1.6, 3.4
3. Design and development	Design the EWRS framework and implement it as a software prototype.	Chapters 4 and 5
4. Demonstration	Run the EWRS prototype using selected target domains and Passive, Active and Hybrid scan modes.	Sections 3.5–3.6 and Chapter 6
5. Evaluation	Evaluate discovery, DNS validation, live web services, port/service discovery, duplicate reduction, exposure scoring and reporting.	Section 3.7 and Chapter 6

6. Communication	Present the design, implementation, evaluation, findings, limitations and contribution through the thesis.	Chapters 4-8

3.5 Data Collection and Testing Approach

The data collection and testing approach forms part of the demonstration and evaluation stages of the Design Science Research process and data for this thesis is collected through practical testing of the EWRS prototype using selected target domains so during each test the scan configuration, scope options and required modules are selected before starting the scan and the outputs produced by the prototype are then collected and used as evidence for evaluating the artifact.

The testing process starts with the target domain input and after entering the domain the user selects the scan mode, such as passive, active, or hybrid and the user can also select scope options such as including subdomains, resolving DNS records, and including HTTP probing and after that the required modules are selected, including passive reconnaissance, Amass reconnaissance, active validation, DNS checks, HTTP probe, port scan, and exposure analysis.

When the scan starts the EWRS runs the selected modules and collects the results from each stage and the collected data includes candidate assets, DNS-resolved assets, live web services, unique IP addresses, open ports , scan logs, findings, and report output and these results are displayed in different parts of the GUI, such as the dashboard, scan output, findings, and reports tabs.

After the scan is completed, the results are reviewed and organized and duplicate results are removed where necessary and the output is checked to understand which assets were discovered, which assets exposed live web services and which services or ports were exposed and the final results can also be exported as TXT, JSON, or CSV files for further analysis.

The purpose of this testing approach is not to exploit vulnerabilities. The purpose is to evaluate whether EWRS can collect, validate, organize, and report external reconnaissance information in a structured way and this makes it possible to assess how well the framework supports external asset discovery and improves the reconnaissance workflow.

For the manual workflow comparison, Subfinder, Amass, httpx and Nmap were also executed separately through PowerShell using selected target domains and their outputs were recorded and compared with the corresponding stages of the EWRS workflow and the comparison focused on tool execution, result organization, validation, deduplication, exposure analysis and reporting so the purpose was to evaluate workflow integration rather than to benchmark or replace the technical capabilities of the individual tools.

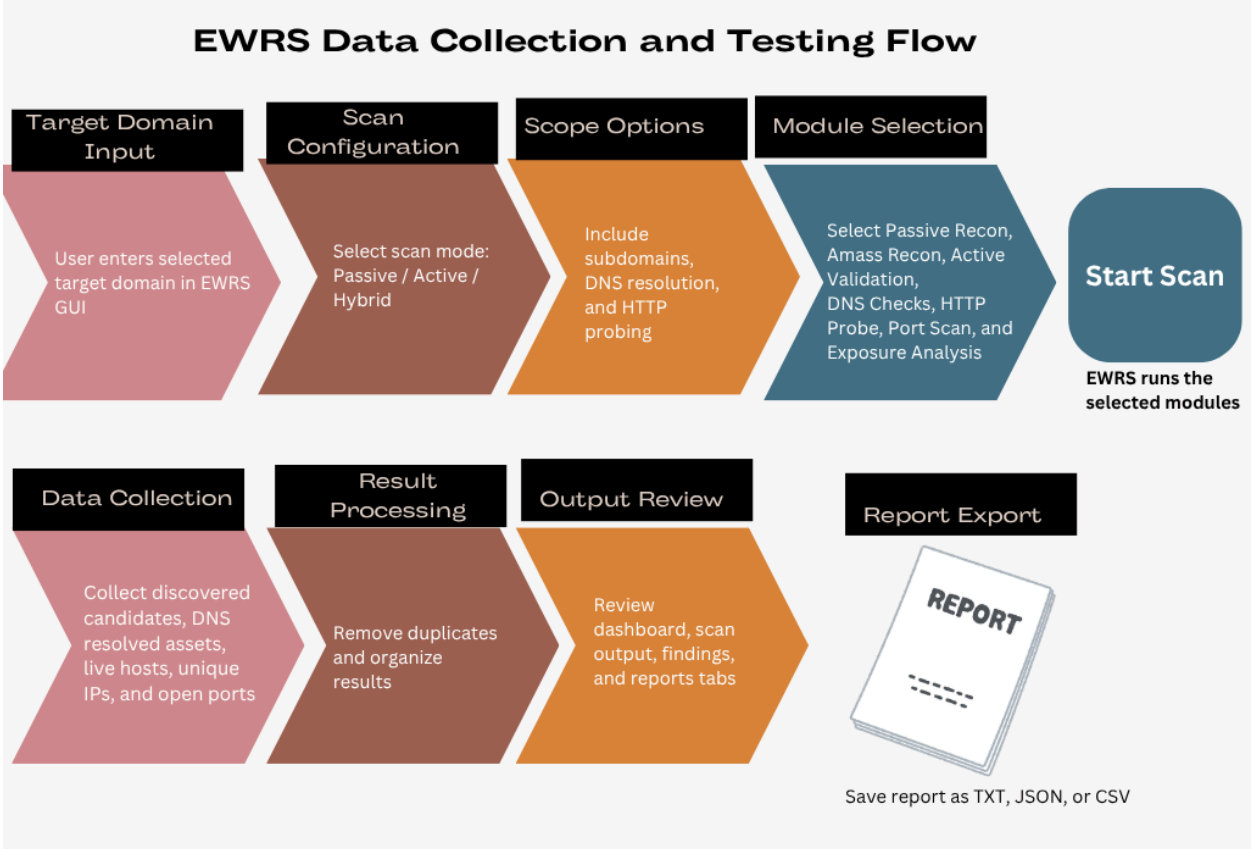


Figure 3.2 : EWRS data collection and testing flow

3.6 Scan Modes Used in EWRS

EWRS provides three scan modes the Passive Mode, Active Mode and Hybrid Mode and these modes allow the user to control how reconnaissance is performed and each mode has a different purpose in the workflow so the passive Mode focuses on discovery, Active Mode focuses on validation and checking and Hybrid Mode combines both discovery and validation.

The scan modes are important because passive and active reconnaissance have different roles. So the passive reconnaissance is useful for collecting possible external assets with limited direct interaction and while active reconnaissance is useful for confirming whether assets are reachable and exposing services. In EWRS, these modes help organize the reconnaissance process into clear workflows.

3.6.1 Passive Mode

Passive Mode is used for discovering possible external assets without performing active validation and after the user enters the target domain the EWRS validates and normalizes the target and If the target is invalid, the scan stops and an error is returned.

If the target is valid, EWRS starts passive discovery and when the Passive Recon module is selected, Subfinder is used to collect possible subdomains the fallback candidates are also generated from the target domain and If the Amass Recon module is selected, Amass is executed and its discovered domains are added to the candidate list and the collected candidates are then merged, organized, and displayed as passive results.

In Passive Mode, DNS validation, HTTP probing and Nmap scanning are not performed and the purpose of this mode is to create an initial list of possible domains and subdomains that can later be validated using active checks.

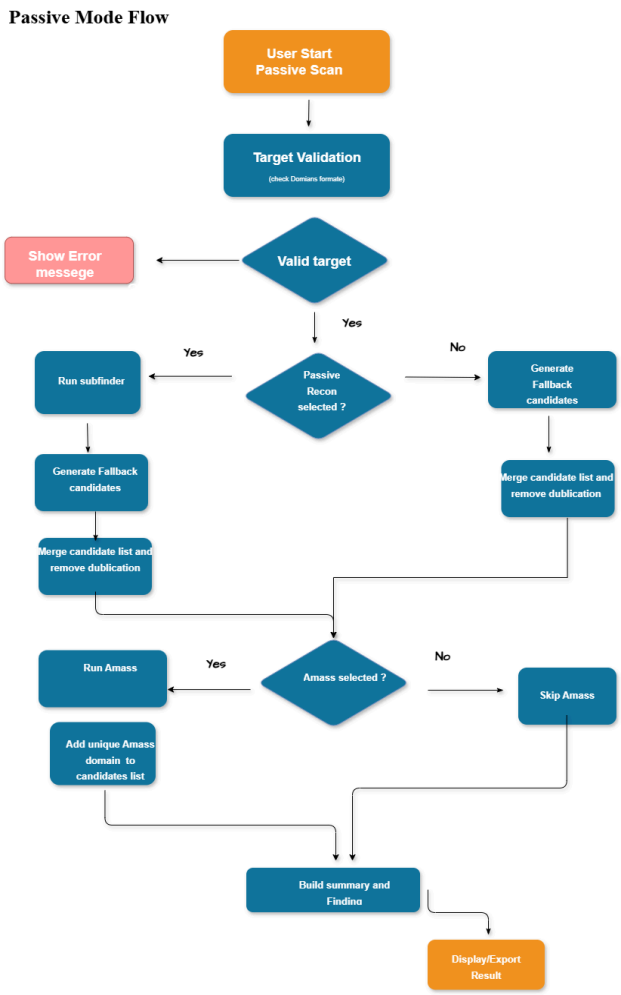


Figure 3.3: Passive Mode Flow

3.6.2 Active Mode

Active Mode is used for validation and checking rather than passive discovery and after the target domain is entered the EWRS validates and normalizes the target and if the target is invalid, the scan stops and an error is returned.

If the target is valid, EWRS generates fallback candidates from the original target domain and common in scope candidate and in Active Mode the Subfinder and Amass are not executed and if DNS resolution is enabled, EWRS checks whether the generated candidates resolve to IP addresses so the results are marked as resolved or unresolved.

If HTTP probing is enabled the httpx is used to check whether the resolved assets expose live HTTP or HTTPS services and if the Port Scan module is selected, Nmap scans the resolved IP addresses for open ports so finally, the EWRS builds the findings and summary and displays or exports the results.

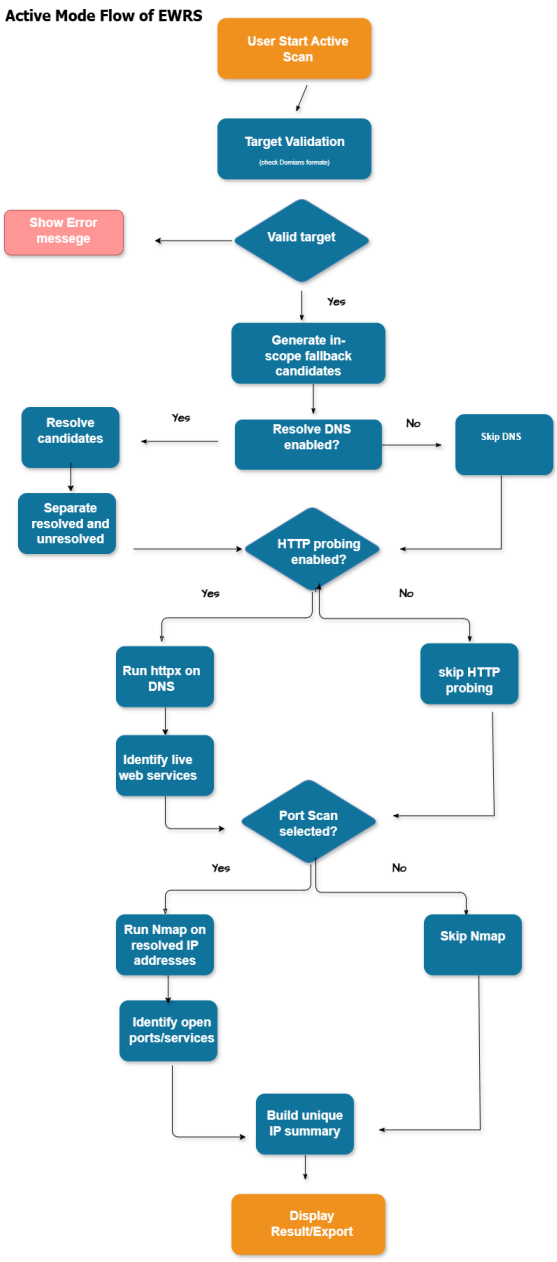


Figure 3.4: Active Mode Flow

3.6.3 Hybrid Mode

Hybrid Mode combines passive discovery and active validation in one workflow and after the target domain is entered, the EWRS validates and normalizes the target and if the target is invalid, the scan stops and an error is returned.

If the target is valid, EWRS runs Subfinder and generates fallback candidates and this creates an initial list of possible domains and subdomains and if the Amass Recon module is selected, Amass is also executed and its discovered domains are added to the candidate list and the collected candidates are then merged and duplicate results are removed.

After discovery and cleaning, Hybrid Mode continues with active validation and if DNS resolution is enabled, EWRS resolves the candidates and separates resolved and unresolved assets and if HTTP probing is enabled, httpx checks the resolved assets for live HTTP or HTTPS services. If the Port Scan module is selected the Nmap scans the resolved IP addresses for open ports and finally the EWRS builds the findings and summary and displays or exports the results.

Hybrid Mode is the most complete scan mode because it combines asset discovery and validation however, some stages still depend on the selected modules and scope options.

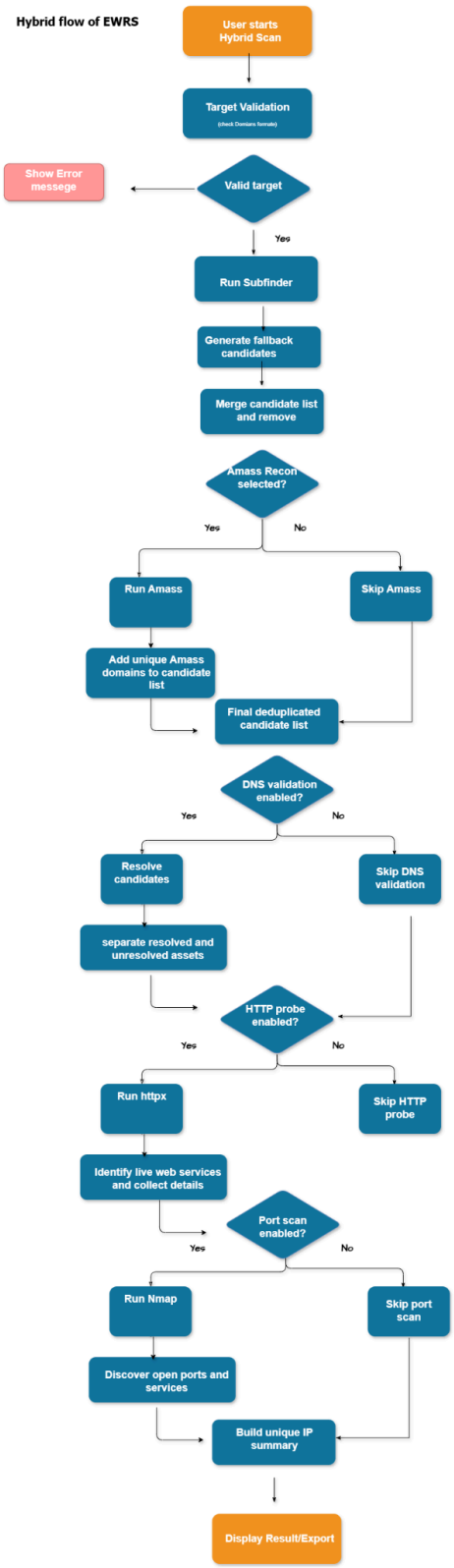


Figure 3.5: Hybrid Mode Flow

3.7 Evaluation Criteria

The evaluation criteria are used during the evaluation stage of the Design Science Research process [14]. The EWRS prototype is evaluated using practical criteria related to external web reconnaissance to determine how well the implemented artifact addresses the identified the problem [13,14]. The evaluation focuses on asset discovery, validation, result organization, exposure analysis and reporting.

So the first evaluation criterion is the number of discovered assets so this includes domains and subdomains collected through passive discovery and fallback candidate generation and this criterion helps measure how well EWRS supports the discovery stage.

The second criterion is DNS validation and this checks how many discovered assets resolve to valid IP addresses and it helps to separate DNS resolved assets from unresolved records.

The third criterion is live web service validation. This checks how many DNS resolved assets respond over HTTP or HTTPS through HTTP probing

The fourth criterion is the port and service discovery and this checks which ports and services are exposed on reachable assets when the Port Scan module is selected.

The fifth criterion is duplicate reduction and result organization so the EWRS should reduce repeated entries and present results in a cleaner structure so that the user can understand the output more easily.

The sixth criterion is reporting so the prototype is evaluated based on whether it can display results clearly in the GUI and export reports in useful formats such as TXT, JSON, and CSV.

These criteria are used to evaluate whether EWRS improves the reconnaissance workflow by combining discovery, validation, cleaning and reporting into one framework.

3.8 Ethical Considerations

Ethical considerations are important in this thesis because EWRS includes active reconnaissance functions such as DNS checks, HTTP probing and port scanning and Active reconnaissance interacts directly with target systems and can generate network traffic. Research has shown that active reconnaissance techniques, particularly port and vulnerability scanning, can affect system availability or cause operational disruption in some environments so therefore, active scanning should be performed carefully and within a controlled scope [31].

The purpose of EWRS is not to exploit vulnerabilities or gain unauthorized access and the framework is designed to support external asset discovery, validation and reporting and it

identifies domains, subdomains, live web services, IP addresses and exposed services but it does not perform exploitation or attack activities.

Security testing should also be planned within clearly defined boundaries. NIST recommends that an assessment plan should identify the systems and networks to be assessed, the type and level of testing that is permitted and the rules that assessors must follow. NIST also emphasizes appropriate approval, coordination and legal considerations before security assessment activities are performed so therefore when EWRS is used in a real organizational environment, active scanning should only be performed within an authorized and clearly defined scope [32].

This ethical approach is important because reconnaissance can be used for both defensive and offensive purposes so in this thesis the EWRS is developed and evaluated from a defensive and educational perspective so the goal is to improve external attack surface visibility and support responsible security testing [3].

3.9 Summary

This chapter explained the research methodology used in this thesis so the study follows Design Science Research because the main purpose is to design, develop, demonstrate, and evaluate a practical artifacts and in this thesis, the research artifact consists of the proposed EWRS framework and its implemented software prototype.

The chapter described the Design Science Research Process and explained how each step is applied to EWRS and the problem is the fragmented nature of external web reconnaissance, and the objective is to create a structured framework that combines passive discovery, active validation, duplicate removal, and reporting.

The chapter also explained the data collection and testing approach. The EWRS is tested through selected target domains using its GUI, scan modes, scope options, and selected modules and the chapter further described the three scan modes used in EWRS: Passive Mode, Active Mode, and Hybrid Mode and these modes help organize discovery and validation activities based on the testing purpose.

Finally the chapter presented the evaluation criteria and ethical considerations. EWRS is evaluated based on discovered assets, DNS validation, live web service validation, port scanning results , duplicate reduction and report quality and ethical use is important because active reconnaissance can interact with external systems therefore the EWRS should be used only in controlled, authorized and responsible testing contexts.

Chapter 4

Proposed EWRS Framework

4.1 Introduction

This chapter is presents the proposed of External Web Reconnaissance System, called EWRS. The purpose of the framework is to improve external attack surface visibility by combining passive discovery, active validation, result cleaning, exposure analysis and reporting in one structured workflow.

The need for this type of framework comes from the fact that external attack surface management depends on discovering and monitoring internet facing assets such as domains, subdomains, IP addresses, web services, certificates and exposed services and existing research on EASM and reconnaissance shows that external visibility requires different techniques, including passive information gathering, active checking, subdomain discovery, DNS-related analysis, HTTP validation and service scanning [1,3].

The EWRS framework represents the proposed design of the research artifact and is implemented through the software prototype described in Chapter 5 and the framework does not aim to replace existing reconnaissance tools so instead, it integrates selected tools and techniques into one workflow and this design choice supports the main goal of the thesis which is to reduce fragmentation, manual work, duplicate results and unclear reporting in external web reconnaissance.

The framework provides three scan modes: Passive Mode, Active Mode, and Hybrid Mode and the passive Mode focuses on discovering possible external assets and active Mode focuses on validating reachable assets and exposed services and hybrid Mode combines passive discovery and active validation to provide a more complete workflow and these modes allow the user to select the level of reconnaissance based on the testing purpose and scope.

This chapter explains the overall design of EWRS and its architecture, workflow, core modules, exposure scoring model, reporting process and scope limitations.

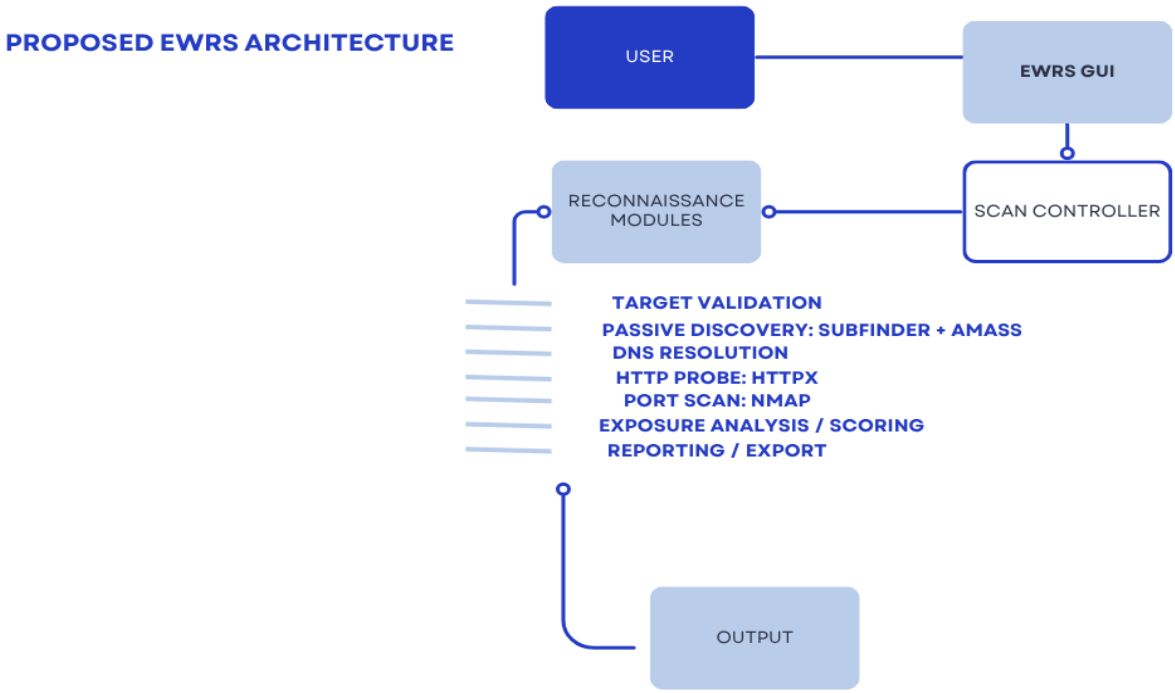


Figure 4.1:Proposed EWRS architecture

4.2 Overview of the Proposed EWRS Framework

The proposed EWRS framework is designed to support external web reconnaissance in a structured and automated way and the framework combines different reconnaissance stages into one workflow so that the user can discover, validate, organize and report externally visible assets from one interface and this supports the main goal of improving external attack surface visibility.

EWRS is built around the idea that passive and active reconnaissance provide different types of value and the passive reconnaissance helps collect possible external assets such as domains and subdomains from public sources and while active reconnaissance helps validate which assets are reachable and which services are exposed and existing research shows that external asset discovery and attack surface management often require multiple techniques such as OSINT, subdomain discovery, DNS checks, scanning and reporting[1,3].

The framework includes three scan modes Passive Mode, Active Mode and Hybrid Mode. Passive Mode is used for collecting possible assets without active validation and the active mode is used for validating assets through DNS checks, HTTP probing, and port scanning and the

hybrid mode combines passive discovery and active validation in one workflow and this gives the user flexibility to choose the scan type based on the purpose and scope of the test.

EWRS integrates selected tools into its workflow. Subfinder and Amass are used to support passive discovery and the DNS checks are used to confirm whether discovered assets resolve to IP addresses and the httpx is used to check live HTTP and HTTPS services, and Nmap is used for port scanning and service discovery and the results are then processed, cleaned, and displayed in the GUI so the EWRS prototype also supports exporting reports in TXT, JSON, and CSV formats.

The proposed framework does not claim to replace manual security testing or vulnerability assessment and instead it provides an organized reconnaissance workflow that helps identify externally visible assets and prioritize them for further review and this makes EWRS useful as an early stage reconnaissance and external visibility support tool.

4.3 EWRS Architecture

The EWRS architecture is to designed as a modular framework and the EWRS framework is organized into separate components so that each part of the reconnaissance process can be managed clearly and the main components of the framework are the graphical user interface, scan controller, reconnaissance modules, result processing component, exposure analysis component and reporting component.

The graphical user interface allows the user to enter a target domain and then select the scan mode and choose scope options and enable or disable modules and this makes the prototype easier to use because the user does not need to run each tool manually from the command line.

The scan controller manages the overall workflow and It receives the selected configuration from the GUI and decides which modules should run and it also controls the order of execution, such as passive discovery, DNS resolution, HTTP probing, port scanning, result cleaning, exposure analysis and reporting.

The reconnaissance modules perform the main technical tasks and subfinder supports passive subdomain discovery [8], Amass supports external asset discovery and attack surface mapping [10], httpx supports HTTP/HTTPS probing [7] and Nmap supports port scanning and service discovery [12] and these modules allow EWRS to combine different reconnaissance tasks into one structured workflow.

After the modules complete their task is the result processing component organizes the collected data and it removes the duplicate entries and separates resolved and unresolved assets, identifies

live web services and prepares the results for the findings and report sections and this helps reduce manual work and makes the final output easier to understand.

The reporting component presents the final output in the EWRS interface and allows the user to export reports in TXT, JSON, and CSV formats. This supports further manual review and documentation of discovered external assets.

4.4 EWRS Workflow

The EWRS workflow starts when the user enters a target domain into the graphical user interface and the EWRS first validates and normalizes the target to make sure that the input is suitable for scanning and if the target is invalid the scan is stopped and an error message is returned.

After the target is validated the EWRS follows the selected scan mode and module configuration so if the use select the passive mode so in Passive Mode, the framework focuses on discovering possible external assets such as domains and subdomains and if the user select the active mode so in Active Mode the framework focuses on validation activities such as DNS resolution, HTTP probing, and port scanning and in Hybrid Mode the both passive discovery and active validation are combined into one workflow.

During passive discovery, EWRS uses tools such as Subfinder and Amass to collect candidate domains and subdomains and the collected results are then merged and duplicate entries are removed and this step is important because different tools may return the same asset more than once.

After discovery and cleaning the active validation can be performed if the relevant options are enabled and DNS checks are used to verify whether discovered assets resolve to IP addresses and HTTP probing is used to identify live HTTP or HTTPS services and if a port scanning is selected and the Nmap is used to check exposed ports and services on reachable assets.

The final stage of the workflow is result processing and reporting and EWRS organizes the collected data into clear output sections, such as candidate assets, DNS-resolved assets, live web services, open ports and finding and the results are displayed in the GUI and can also be exported in TXT, JSON and CSV formats for further review.

4.5 EWRS Modules

EWRS is divided into several more modules so that each part of the reconnaissance process can be handled clearly and easily so the modular design makes the framework easier to manage, test

and extend and each module has a specific role, such as validating the target, discovering assets, checking DNS resolution, probing HTTP services, scanning ports, analyzing exposure or generating reports.

The main modules in EWRS are

- Target Input and Validation Module
- Passive Discovery Module
- Active Validation Module
- HTTP Probe Module
- Port Scan Module
- Exposure Analysis and Scoring Module
- Reporting and Export Module

4.5.1 Target Input and Validation Module

The target input and validation module is the first step in the EWRS workflow and the user enters a target domain through the graphical user interface and the EWRS they can validates and normalizes the input before any reconnaissance module is executed.

This step is important because invalid input can cause incorrect results or failed scans and if the entered target is not valid so the EWRS stops the scan and returns an error message and if the target is valid the normalized domain is passed to the selected scan mode and modules.

This module helps ensure that the scan starts with a clean and consistent target value and it also supports better result organization because all later outputs are connected to the validated target domain.

4.5.2 Passive Discovery Module

The passive discovery module is used to collect possible external assets without performing active validation and in EWRS this module mainly focuses on discovering domains and subdomains that may belong to the target.

Subfinder is used in EWRS for passive subdomain discovery and it collects valid subdomains for a target domain from passive online sources, which makes it suitable for the initial discovery stage before DNS resolution and HTTP probing are performed [8].

Amass is also used in the passive discovery stage when the Amass Recon module is selected so the OWASP Amass supports external asset discovery and attack surface mapping by collecting information about domains, subdomains, DNS records, and related external infrastructure [10].

The results from Subfinder, Amass, and fallback candidate generation are merged into one candidate list and duplicate entries are removed so that the next stages work with a cleaner set of discovered assets so in Passive Mode, these results are displayed as passive candidate and in Hybrid Mode, they can continue to active validation stages such as DNS checks and HTTP probing.

4.5.3 DNS Resolution and Active Validation Module

The DNS resolution and active validation module is used to check whether discovered domains and subdomains resolve to valid IP addresses and this step helps to separate assets that are technically reachable from assets that may be old, inactive or no longer connected to an active system.

In EWRS, DNS resolution is performed when the Resolve DNS option is enabled and EWRS takes the candidate assets collected from passive discovery or fallback generation and checks whether they resolve to IP addresses and assets that resolve successfully are marked as resolved while assets that do not resolve are marked as unresolved.

This module is important because passive discovery alone does not confirm whether an asset is still active and a subdomain may appear in public sources or tool output but it may no longer point to a working system and DNS validation therefore helps improve the quality of the results before HTTP probing or port scanning is performed.

Research on reconnaissance and active DNS also shows that DNS checking is an important part of understanding domain and IP infrastructure. Active DNS datasets can support security analysis by collecting DNS information through systematic queries [3,6].

4.5.4 HTTP Probe Module

The HTTP probe module is used to check whether resolved assets expose active web services over HTTP or HTTPS and in EWRS, this module uses httpx to perform HTTP probing on resolved assets when HTTP probing is enabled.

This step is important because DNS resolution only shows that an asset points to an IP address and it does not confirm whether a web service is running and HTTP probing helps identify live web services and can collect useful response information such as HTTP status codes, page titles, and other response metadata.

In the EWRS workflow the HTTP probing is used after DNS resolution and assets that respond over HTTP or HTTPS are treated as live web services and can be included in the findings and

reports and this helps the user focus on assets that are reachable and relevant for further manual review.

httpx is suitable for this purpose because it is designed as an HTTP toolkit for probing web servers, HTTP responses, and related metadata [7].

4.5.5 Port Scan Module

The port scan module is used to identify open ports and exposed services on reachable assets. In EWRS this module uses Nmap when the Port Scan module is selected and the scan is performed on resolved IP addresses so that the EWRS can identify which services are exposed from the outside.

Port scanning is useful because open services can increase the external attack surface so for example, a host may expose web services, mail services, SSH, FTP or other network services. These services are not treated as confirmed vulnerabilities by EWRS but they provide useful information for further manual security review.

Nmap supports port scanning, service discovery and network discovery features which makes it suitable for the active reconnaissance stage of EWRS [12] and Research on reconnaissance also discusses port scanning and service discovery as important techniques for collecting information about target systems[3].

4.5.6 Exposure Analysis and Scoring Module

The Exposure Analysis and Scoring Module is used to organize reconnaissance findings and help identify which externally visible assets may require earlier manual review and the purpose of this module is not to confirm vulnerabilities or calculate the actual security risk of an organization. Instead it uses information that can be observed from the public internet to provide a simple exposure prioritization score for the assets identified by EWRS.

The scientific basis for this approach comes from previous research on external security measurements. Edwards et al. showed that externally observable conditions can be used as **risk vectors** when assessing security posture and their study used external measurements such as publicly available network services, TLS configuration problems and other observable conditions and found relationships between several of these indicators and security outcomes [33]. The study therefore shows that externally observable technical information can provide useful evidence when assessing and prioritizing security exposure. However the authors also make clear that these relationships should not automatically be interpreted as causal [33].

EWRS adapts this general idea to external web reconnaissance and the prototype uses the external information available from its own reconnaissance workflow, including DNS resolution, live HTTP/HTTPS services, hostname information, HTTP responses and externally exposed ports and services. Network port and service identification is also recognized in security testing guidance as a useful technique for identifying active services and externally visible technical information [32].

The EWRS scoring model itself is a researcher designed rule based model. The exact indicators, point values and thresholds used by EWRS are not taken directly from Edwards et al. and they are not statistically derived from that study. Instead, the previous research provides support for the general principle of using externally observable evidence, while the EWRS rules were designed as part of the research artifact to demonstrate how different reconnaissance findings can be combined for prioritization.

The score is calculated at the IP level and this means that reconnaissance evidence belonging to hostnames that resolve to the same public IP address can be combined and this is useful because several hostnames may point to the same server and the same IP address may expose several different network services.

EWRS uses a score from **0 to 10** and 0 - 10 range was selected as a simple and familiar way of presenting the final prioritization result and CVSS also uses a 0-10 numerical scale for communicating the severity of known vulnerabilities [34]. However, EWRS does not implement CVSS and the EWRS score must not be interpreted as a CVSS score. CVSS is intended for known vulnerabilities, while EWRS only uses reconnaissance evidence to prioritize externally visible assets [15,34].

Table 4.1: EWRS Exposure Score Levels

Table 4.1 presents the three EWRS exposure levels, while Table 4.2 shows the indicators and heuristic score contributions used by the prototype.

Score range	Exposure level	Meaning
0–3	**Low**	Limited externally visible evidence was identified and the asset may be resolved or reachable, but only a small number of exposure indicators are present.
4–6	**Medium**	Several externally visible indicators are present, such as a live web service, hostname information or additional exposed services. The asset may require further manual review.

7–10	**High**	Multiple or stronger external exposure indicators are present and the asset should receive higher priority for further manual security review.

Table 4.2: EWRS Exposure Scoring Indicators

Evidence / indicator	Score contribution
DNS resolved public IP or validated hostname	+1
Live HTTP/HTTPS service detected on the same IP	+2
Sensitive hostname keyword such as dev, test, staging, admin, api, portal, login, cpanel, webmail or webdisk	+2
Restricted HTTP response such as 401 or 403	+2
Server error response such as 500 - 599	+2
Nmap identifies at least one open port	+1
Higher-priority exposed service identified by EWRS, such as FTP, SSH, Telnet, SMTP, MySQL, RDP, PostgreSQL, Redis or Elasticsearch	+3 each
Mail related service such as POP3, IMAP, SMTPS, Submission, IMAPS or POP3S	+2 each
Other non-web open port	+1 each
More than 5 open ports on the same IP	+2
More than 10 open ports on the same IP	+3

The scoring model is additive and the final value is capped at 10 and the individual point values represent heuristic design choices made for the EWRS prototype. They are intended to support prioritization and have not been statistically calibrated as probabilities of compromise or measures of vulnerability severity so therefore a High exposure score means that the asset contains more or stronger externally observable indicators and should be reviewed earlier and it does not mean that the asset has a confirmed High severity vulnerability.

Normal public web ports such as 80, 443, 8080, 8443 and 8000 are recorded as exposure evidence but they do not receive an additional service score when HTTP probing has already confirmed the web service and this avoids counting the same web exposure twice and the score increases when additional evidence is identified such as sensitive hostname information, restricted interfaces, additional network services or several open ports on the same public IP.

4.5.7 Reporting and Export Module

The Reporting and Export Module is used to present the final results of the EWRS scan in a clear and structured format and after the selected reconnaissance modules finish running the EWRS organizes the collected information and displays it in different sections of the graphical user interface such as the dashboard, scan output, findings, and reports tabs.

The dashboard provides a quick summary of the scan results, including discovered assets, live web services , findings, and high-priority exposure indicators and the scan output section shows the detailed module output while the findings section presents the most relevant results in a more organized way and this helps the user understand the scan results without manually reading and combining raw outputs from different tools.

The export function allows the user to save the results in different formats including TXT, JSON and CSV and the TXT reports are useful for readable documentation and the JSON output is useful for structured data storage or later automation and CSV output is useful for tabular analysis or comparison and this supports the goal of EWRS by making the results easier to review, share and analyze.

Clear reporting is important because reconnaissance data can become difficult to manage when it comes from different tools and contains duplicate or unorganized entries and EASM research also highlights reporting and prioritization as important parts of managing externally visible assets and supporting follow up security actions [1]. In EWRS the reporting module helps reduce this problem by presenting the results in a single structured output and this support external attack surface visibility and helps users prioritize assets for further manual security review.

4.6 Public Metadata and Scope Limitation

EWRS is designed to collect and report only publicly available technical metadata and the framework does not access private systems, private files, mailboxes, databases, credentials, or internal server content and its purpose is to improve external attack surface visibility by showing what information is already visible from the public internet.

The data collected by EWRS includes domain names, discovered subdomains, DNS resolution results, public IP addresses and HTTP/HTTPS response information, status codes, page titles, and open port information when port scanning is enabled and these are treated as external metadata because they can be observed from outside the organization without logging in to private systems and However the public metadata can still be security relevant because IP addresses and related network level information may reveal useful information about externally visible web services and their relationships[24].

This distinction is important because some reconnaissance results may include mail related DNS records, IP addresses, or exposed services and in EWRS these results are not treated as private

server access and if we see the previous work on Certificate Transparency also shows that publicly available certificate metadata can support subdomain discovery and may reveal information about organizations and which reinforces the need to treat reconnaissance outputs carefully and ethically[25]. for example to identifying a mail related record or an open mail service only means that the service is externally visible and the EWRS does not access email accounts, read mailbox content, authenticate to mail servers or collect private messages.

Similarly when EWRS reports IP addresses or open ports it only reports externally observable network information and it does not exploit the services, bypass authentication, upload files, modify configurations or attempt to gain unauthorized access and the exposure score is also based only on observable indicators and does not claim that a confirmed vulnerability exists.

This scope limitation is important for ethical and responsible use and reconnaissance techniques can be used for both defensive and offensive purposes so the EWRS is intended only for controlled, authorized and educational security testing and the framework supports visibility and prioritization not exploitation and the previous research also explains that reconnaissance can be used by attackers as well as by security researchers and defensive teams which makes responsible scope control important [3].

4.7 Summary

This chapter is presented the proposed EWRS framework and the framework is designed to improve external attack surface visibility by combining passive discovery, active validation, result processing, exposure analysis and reporting in one structured workflow.

The chapter explained the overall architecture of EWRS including the graphical user interface, scan controller, reconnaissance modules, result processing, exposure scoring and reporting components and it also described that how EWRS supports different scan modes and how the workflow moves from target input to final report output.

The chapter also described the main modules of the EWRS and these include target input and validation, passive discovery, DNS resolution and active validation, HTTP probing, port scanning, exposure analysis and scoring and reporting and export and each module has a specific role in the framework and supports the overall goal of making reconnaissance more organized and easier to manage.

Finally the chapter explained the important scope limitation of the EWRS collects and reports only publicly available technical metadata and it does not access private server contents, mailboxes, databases, credentials, or perform exploitation and this ensures that the framework remains focused on external visibility, prioritization and responsible security testing.

Chapter 5

Design and Implementation

5.1 Introduction

This chapter explains the design and implementation of the EWRS prototype and the purpose of this chapter is to describe how the proposed framework was developed and how its main components work together to support external web reconnaissance and while Chapter 4 described the proposed framework at a design level this chapter focuses on the practical implementation of the prototype.

EWRS was implemented as a graphical user interface based application that allows the user to enter a target domain and then select a scan mode and choose scope options, enable or disable reconnaissance modules, run the scan and view results and as well as export reports. The prototype integrates different reconnaissance tools and modules into one workflow so that the user does not need to run each tool separately from the command line.

The implementation includes several main parts like the graphical user interface, scan configuration controls, scan controller, passive discovery functions, active validation functions, HTTP probing, port scanning, exposure analysis, result processing, and report export and these parts work together to collect external reconnaissance data, organize it, and present it in a clearer format.

The chapter also explains the tools and technologies used to build EWRS and these include Python, GUI libraries, external reconnaissance tools such as Subfinder, Amass, httpx and Nmap and export formats such as TXT, JSON and CSV and also the screenshots of the prototype are also included to show how the prototype works from the user's perspective.

5.2 Tools and Technologies

EWRS was developed using a combination of programming tools, GUI components, and external reconnaissance tools and the main purpose of selecting these technologies was to build a working prototype that can automate passive discovery, active validation, port scanning, exposure analysis and reporting in one interface.

5.2.1 Programming Language

Python was used as the main programming language for developing EWRS. Python was selected because it supports scripting, automation, external command execution, file handling, and data processing and in EWRS, Python is used to connect the graphical interface with backend reconnaissance functions, run selected modules, process outputs, remove duplicates, calculate exposure scores, and export reports and the Python standard library also provides modules such as subprocess which supports running external tools and collecting their outputs[16].

5.2.2 Graphical User Interface Library

The EWRS prototype uses CustomTkinter to build the graphical user interface and the customTkinter is a Python desktop UI library based on Tkinter and provides modern, customizable widgets for creating desktop applications[17] and in EWRS it is used to create the target input field, scan mode selection, module checkboxes, dashboard cards, output tabs, and report export buttons.

5.2.3 External Reconnaissance Tools

EWRS integrates several external tools to perform specific reconnaissance tasks. Subfinder is used for passive subdomain discovery because it collects valid subdomains for a target domain from passive online sources[8] and Amass is used for external asset discovery and attack surface mapping when the Amass Recon module is selected [10].

For active validation the EWRS uses httpx to check whether discovered or resolved assets expose live HTTP or HTTPS services and httpx is suitable for this task because it is designed for probing web servers, HTTP responses, and related metadata [7] and the Nmap is used for port scanning and service discovery when the Port Scan module is selected and also the Nmap supports host discovery, port scanning, service detection, and network exploration [12].

5.2.4 Output and Export Formats

EWRS supports different output formats to make the results easier to review and reuse and the results are displayed inside the GUI through dashboard, scan output, findings and reports sections and the prototype also supports exporting results in TXT, JSON, and CSV formats.

TXT output is useful for readable reports and the JSON is useful for structured data storage or later automation and CSV is useful for tabular analysis or comparison and these export options support the goal of making reconnaissance results clearer and easier to use for further manual review.

5.3 GUI Design and User Interface

The EWRS prototype includes a graphical user interface to make the reconnaissance workflow easier to control and the interface allows the user to enter a target domain and then select the scan mode, choose scope options, enable or disable modules, start the scan, view results, and export reports from one place.

The GUI is divided into several main areas so the left side contains the target input field, scan mode selection, scope options, and module selection and these controls allow the user to decide how the scan should be performed and the main area displays dashboard cards, scan output, findings, and report information and this design helps the user manage the reconnaissance workflow without manually running each tool separately from the command line.



Figure 5.1: EWRS graphical user interface showing scan configuration and scan output

EWRS provides three scan modes in the interface: Passive, Active, and Hybrid so in passive mode focuses on discovery, Active Mode focuses on validation and checking while in Hybrid Mode combines both discovery and validation and the scan mode selection helps the user control the level of reconnaissance based on the testing purpose.

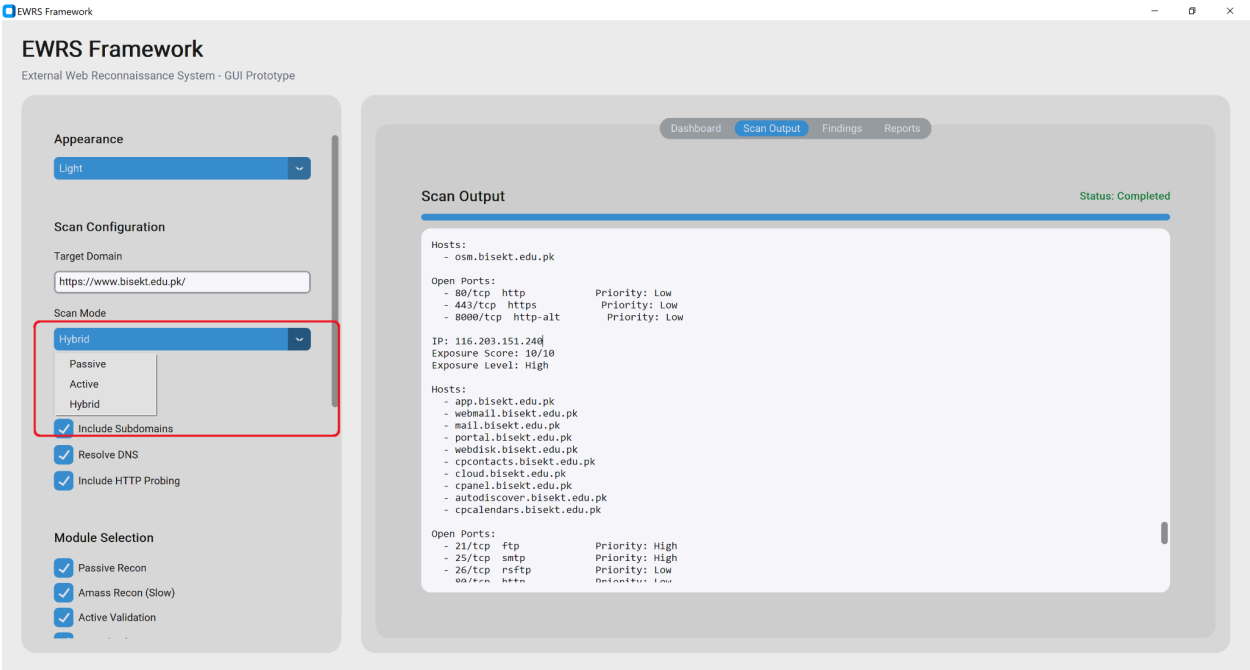


Figure 5.2: Scan mode selection in EWRS

The module selection area allows the user to enable or disable specific reconnaissance functions and these include Passive Recon, Amass Recon, Active Validation, DNS Checks, HTTP Probe, Port Scan and Exposure Analysis and this modular design gives the user more control because not every scan requires every module.

The GUI also includes the output and reporting areas and the dashboard gives a quick summary of the scan while the scan output tab shows detailed module results and the findings the tab highlights important results and the reports section supports exporting the output in TXT, JSON and CSV formats and this helps make the scan results easier to understand, store and review later.

5.4 Backend Implementation

The backend implementation of the EWRS is responsible for controlling the scan workflow and connecting the graphical user interface with the reconnaissance modules and when the user enters a target domain and selects the scan configuration the backend receives these inputs and runs the required modules based on the selected mode and scope options and module checkboxes.

The scan controller is the main part of the backend and it validates and normalizes the target domain reads the selected scan mode and checks which modules are enabled and then controls the order of execution and depending on the selected configuration the controller may run

passive discovery, DNS resolution, HTTP probing, port scanning, exposure analysis and report generation.

The backend also handles the result processing and after each module finishes the output is collected and organized into structured data and duplicate candidate assets are removed and resolved and unresolved assets are separated and live web services are identified and port scan results are grouped by IP address and this helps avoid and repeated the results and makes the final output easier to understand.

Another important part of the backend is error handling and if the user enters an invalid target domain the EWRS stops the scan and returns an error message and if a selected external tool does not return results or is not available the EWRS still continues where possible and records the status in the output and this makes the prototype more stable during testing.

The backend finally sends the processed results back to the GUI and these results are displayed in the dashboard, scan output, findings, and reports sections and the same processed data is also used for report export in TXT, JSON, and CSV formats.

5.5 Tool Integration

EWRS integrates the external reconnaissance tools to perform a specific tasks in the workflow and the purpose of tool integration is not to replace the existing tools but to connect them within one automated workflow and each tool contributes to a different stage of reconnaissance such as passive discovery, HTTP probing or port scanning.

The tools are executed by the backend based on the selected scan mode and module options and their outputs are collected, parsed, cleaned and then used by later stages of the EWRS workflow and this integration reduces the need for the user to manually run each tool and combine the outputs separately.

5.5.1 Subfinder Integration

Subfinder is integrated into EWRS to support passive subdomain discovery and when the relevant passive discovery stage is executed the EWRS runs Subfinder for the selected target domain and collects the discovered subdomains and these results are added to the candidate asset list for further processing.

Subfinder was selected because it is designed for passive subdomain discovery and collects valid subdomains from passive online sources[8]. In EWRS the subfinder results are combined with fallback candidates and in some modes with Amass results. Duplicate entries are removed before the results are displayed or passed to active validation.

5.5.2 Amass Integration

Amass is integrated into EWRS as an additional passive reconnaissance source and when the Amass Recon module is selected the EWRS executes Amass and adds its discovered domains and subdomains to the candidate list.

Amass supports external asset discovery and attack surface mapping by collecting information about domains, subdomains, DNS records and related infrastructure [10]. In EWRS the Amass helps improve discovery coverage by providing another source of reconnaissance data and its output is merged with Subfinder and fallback results and duplicate entries are removed before further processing.

5.5.3 httpx Integration

httpx is integrated into EWRS for HTTP and HTTPS probing and after DNS resolution is performed the EWRS can use httpx to check whether resolved assets expose live web services and this helps separate assets that only resolve to an IP address from assets that are actually reachable over HTTP or HTTPS.

httpx is suitable for this function because it is designed to probe web servers, HTTP responses, and related metadata [7]. In EWRS the httpx output may include information such as status codes, page titles, and live web services indicators and these results are used in the findings, reports, and exposure scoring process.

5.5.4 Nmap Integration

Nmap is integrated into EWRS for port scanning and service discovery and when the Port Scan module is selected the EWRS runs Nmap against resolved IP addresses and the purpose is to identify externally visible ports and services that may require further manual review.

Nmap is a widely used tool for network discovery, port scanning, and service detection[12]. In EWRS the Nmap results are grouped by IP address to avoid repeated output when multiple hostnames point to the same server and the open ports and service information are also used by the exposure analysis module to support prioritization.

5.6 Result Processing and Export

After the selected reconnaissance modules complete their execution the EWRS processes the collected results before displaying them to the user and this step is important because raw tool outputs may contain duplicate entries, unresolved assets, repeated IP addresses or information that needs to be organized before it becomes useful.

The result processing component first combines results from different sources like for example, in Passive or Hybrid Mode, discovered domains and subdomains from Subfinder, Amass, and fallback candidates are merged into one candidate list and duplicate entries are removed so that the same asset is not counted more than once.

After this the EWRS organizes the results into separate categories and these may include discovered assets, resolved IP addresses, unresolved assets and live web services , open ports, services, exposure scores and findings and this structure makes the final output easier to understand and compared to reading raw command line output from several tools.

The processed results are displayed in different parts of the graphical user interface and the dashboard gives a very quick overview of the scan while the scan output tab shows the detailed module results and the findings tab highlights important results and the reports tab provides the final structured report.

EWRS also supports exporting results in TXT, JSON and CSV formats and the TXT output is useful for a readable report and the JSON is useful for structured data storage or future automation and CSV is useful for table based analysis or comparison and these export options help users save the results and use them later for manual review or documentation.

The export function supports the main goal of EWRS by reducing manual work and instead of copying results from different tools separately the user can generate a structured output directly from the EWRS prototype and this makes the reconnaissance process more organized and easier to repeat.

5.7 Implementation Challenges

Several implementation challenges were faced during the development of EWRS the one challenge was integrating different external reconnaissance tools into one workflow and the previous research shows that security tools from different vendors may use heterogeneous technologies, different data representations and different ways of operating, which can make integration and interoperability difficult [35]. Islam et al. also identify the inconsistent workflows and lack of standardization for data exchange between separate security tools as important integration problems [35]. In EWRS this challenge was observed because the Subfinder, Amass, httpx and Nmap have different command formats, output structures, execution times and system requirements so therefore the EWRS backend needed to manage tool execution, collect the outputs and organize the results into a consistent structure.

Another challenge was handling tool availability and system path issues so the some external tools may not be available in the system path or may be installed in different locations which can cause execution errors when the EWRS prototype tries to run them so to reduce this problem

EWRS handles execution errors where possible and records the status of the tools in the generated output.

A further challenge was managing duplicate and repeated results so the different reconnaissance sources can produce overlapping information and the same asset may appear through different identifiers. The research on automated security data processing shows that heterogeneous observations can be processed through normalization, deduplication and entity correlation to create a more consistent representation of assets [36]. Baiardi and Sammartino describe a processing pipeline that maps protocol specific information into a common schema, removes redundant observations and correlates different identifiers with a unique asset [36]. In EWRS the passive reconnaissance tools may return the same domain or subdomain more than once while several hostnames may also resolve to the same IP address and the EWRS addresses this by merging candidates, removing duplicate entries and grouping related results by IP address

Execution time was also a challenge and especially when using tools that may take longer to complete and such as Amass or Nmap and to make the workflow more manageable the EWRS allows the user to enable or disable modules depending on the testing purpose and this gives the user more control over the scan scope and execution time and similar challenges are also found in large scale active DNS measurement research and these challenges include handling many DNS queries, controlling scan speed, storing large results, keeping the system stable and making it easy to operate and supporting scalability [26].

Another challenge was presenting technical results in a clear way and the raw reconnaissance output can be difficult to understand if it is shown directly without organization and therefore the EWRS separates results into dashboard summaries, scan output, findings, reports, and export files and this helps the user review the results more easily.

5.8 Summary

This chapter explained the design and implementation of the EWRS prototype and described the tools and technologies used to build the prototype, including Python, the graphical user interface library, Subfinder, Amass, httpx and Nmap.

The chapter also explained the GUI design and how the user can enter a target domain, select scan modes, choose scope options, enable modules, view scan output and export reports. Screenshots were included to show the interface and how the prototype is used from the user’s perspective.

The backend implementation was also described and the scan controller manages the workflow by validating the target, reading the selected configuration, executing selected modules,

processing outputs and sending results back to the GUI and the chapter also explained how EWRS integrates external tools for passive discovery, HTTP probing, and port scanning.

Finally, the chapter described how EWRS processes and exports results and duplicate entries are removed, outputs are organized into clear categories and reports can be exported in TXT, JSON, and CSV formats and the chapter also discussed the main implementation challenges such as tool integration, path issues, duplicate results, execution time and presenting the technical output clearly.

Chapter 6

Evaluation and Results

6.1 Introduction

This chapter presents the evaluation and results of the EWRS prototype and the purpose of the evaluation is to assess how well the EWRS prototype supports external web reconnaissance through asset discovery, validation, result organization, exposure analysis, and reporting and evaluation is an important part of Design Science Research because the developed artifact should be assessed to determine how well it addresses the identified problem[13,14].

The evaluation focuses on the practical use of EWRS through its scan modes and modules and the prototype is tested using selected target domains and the results are reviewed based on the number of discovered assets, DNS-resolved assets, live web services, open ports, exposure levels, duplicate reduction, and report clarity.

The chapter first explains the evaluation setup and test configuration and it then presents the results from the EWRS scan modes and discusses how the framework supports passive discovery, active validation and hybrid reconnaissance and after that the exposure scoring results

are explained and finally, the findings are mapped directly to the research questions to show how the thesis objectives are answered.

6.2 Evaluation Setup

The evaluation of EWRS was carried out by running the prototype on selected of target domains through the graphical user interface and the purpose was to observe how the prototype performs during practical reconnaissance tasks and how well it supports discovery, validation, exposure scoring and reporting.

The evaluation was based on the main of the EWRS scan modes Passive Mode, Active Mode, and Hybrid Mode and each mode was tested to understand its role in the overall workflow so the Passive Mode was used to observe asset discovery and Active Mode was used to observe validation and checking and Hybrid Mode was used to observe the combined discovery and validation process.

During the evaluation the EWRS was collected different types of output depending on the selected modules and these included discovered the domains and subdomains, DNS resolved assets, live web services , open ports, service information and exposure scores as well as the exported reports and also the results were then reviewed to assess whether the prototype produced organized and useful output.

The evaluation criteria included the number of discovered assets the number of DNS resolved assets, the number of live web services , the number of open ports, duplicate reduction, exposure score classification, execution behavior and report clarity and these criteria were selected because they directly relate to the purpose of EWRS which is to improve external attack surface visibility through an automated workflow.

6.3 Test Targets and Scan Configuration

The EWRS prototype was tested using selected target domains and the purpose of selecting target domains was to evaluate how the prototype behaves with real external web assets and how the different scan modes produce results and the selected targets were used only for discovery, validation, and reporting activities, not for exploitation.

For each test the target domain was entered into the EWRS graphical user interface and the scan mode was then selected as Passive, Active, or Hybrid. Scope options such as including subdomains, resolving DNS records, and including HTTP probing were configured depending on the test scenario and the required modules, such as Passive Recon, Amass Recon, DNS Checks, HTTP Probe, Port Scan, and Exposure Analysis, were also enabled or disabled based on the evaluation purpose.

The scan configuration was important because EWRS is modular and different configurations can produce different results. For example the Passive Mode focuses mainly on discovered candidate assets, while Active Mode focuses on validation and checking. Hybrid Mode combines passive discovery and active validation when the relevant modules are enabled.

The results from each configuration were recorded and reviewed and these results included discovered domains and subdomains, resolved IP addresses, live web services , open ports, exposure scores, and exported report outputs and the collected outputs were then used to evaluate whether EWRS supports external asset visibility and structured reconnaissance reporting.

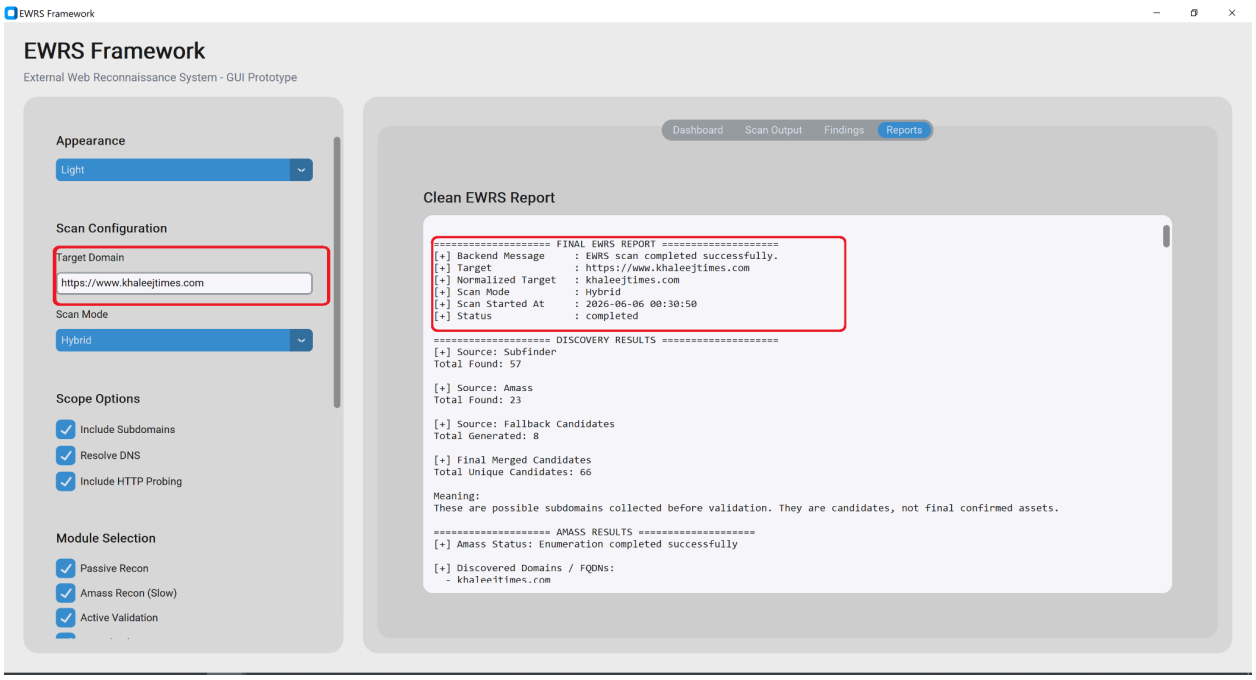


Figure 6.1: EWRS hybrid scan configuration and generated report output

Figure 6.1 shows the EWRS evaluation configuration using Hybrid Mode and also the screenshot shows the selected target domain, enabled scope options, selected reconnaissance modules and the generated clean report and if we see in this example the EWRS completed the scan successfully and produced discovery results from Subfinder, Amass, and fallback candidates before merging the results into a final candidate list.

6.4 Evaluation Results

This section presents the results collected from the EWRS prototype during evaluation and the results are organized according to the scan modes used in the framework Passive Mode, Active

Mode, and Hybrid Mode and each mode was evaluated to understand how it supports to a specific part of the reconnaissance workflow.

Passive Mode was evaluated based on its ability to collect possible external assets such as domains and subdomains and while the Active Mode was evaluated based on its ability to validate assets through DNS resolution, HTTP probing and port scanning and the Hybrid Mode was evaluated as the most complete workflow because it combines passive discovery and active validation.

The evaluation results were reviewed using the criteria defined earlier in this thesis including discovered assets, resolved assets, live web services , open ports, exposure scoring, duplicate reduction and report clarity and the purpose was not to compare EWRS against every existing tool but to show how the prototype supports a structured and automated reconnaissance workflow.

6.4.1 Passive Mode Results

Passive Mode was evaluated to observe how EWRS performs initial asset discovery without active validation and in this mode the framework focuses on collecting possible domains and subdomains through passive reconnaissance sources and selected discovery modules.

During the Passive Mode test, the target domain was entered as https://www.khaleejtimes.com and the EWRS normalized it to khaleejtimes.com. The selected module was Passive Recon and the EWRS completed the scan successfully and used Subfinder to collect passive discovery results. Amass was not selected in this test and the output shows that Subfinder found 93 results, fallback candidate generation added 8 candidates, and after merging and removing duplicates the final number of unique candidates was 98.

The Passive Mode output did not include DNS validated assets, live web services , open ports, or exposure scores and this is expected because Passive Mode is designed for discovery only and does not perform active validation so therefore, the discovered assets are treated as candidate assets, not confirmed live assets.

This result shows that Passive Mode is useful for quickly creating an initial list of possible external assets so however the results require further validation through Active Mode or Hybrid Mode before they can be treated as confirmed reachable assets.

```
==================== FINAL EWRS REPORT ====================
[+] Backend Message     : EWRS scan completed successfully.
[+] Target              : https://www.khaleejtimes.com
[+] Normalized Target   : khaleejtimes.com
[+] Scan Mode           : Passive
[+] Scan Started At     : 2026-04-06 01:25:12
[+] Status              : completed

==================== DISCOVERY RESULTS ====================
[+] Source: Subfinder
Total Found: 93

[+] Source: Amass
Status: Not selected

[+] Source: Fallback Candidates
Total Generated: 8

[+] Final Merged Candidates
Total Unique Candidates: 98

Meaning:
These are possible subdomains collected before validation. They are candidates, not final confirmed assets.

==================== AMASS RESULTS ====================
[+] Amass Status: Not selected

==================== DNS VALIDATED ASSETS ====================
No DNS validated assets found.

Meaning:
These assets resolved to IP addresses, so they are stronger findings than raw candidates.

==================== UNRESOLVED CANDIDATES ====================
No unresolved candidates found.

Meaning:
These were discovered or generated, but DNS did not confirm them. They may be old, inactive, fake, or no longer valid.

==================== UNIQUE IP SUMMARY ====================
No unique IPs found.
Meaning:
Multiple hostnames can point to the same IP. EWRS groups them so the same server is not scanned repeatedly.

==================== HTTP LIVE HOSTS ====================
No live HTTP services found.

Meaning:
These are web services that were reachable through HTTP/HTTPS probing.

==================== EXPOSURE ANALYSIS ====================
No exposure score available.
Exposure scoring requires at least DNS validation or HTTP probing.
Meaning:
Exposure scoring uses all available evidence. DNS and HTTP results create a preliminary score. When Nmap is selected, open-port evidence is added and the score becomes more complete.

==================== EXPOSED SERVICES ====================
No open ports found or Nmap was not selected.
Meaning:
Open ports are shown only when Nmap is selected. Port-level priority explains individual services, while the exposure score explains the overall IP/server exposure.

Main Scoring Criteria:
  - DNS-resolved public IP / validated hostnames: +1
  - Live HTTP/HTTPS service on the same IP: +2
  - Sensitive hostname keyword such as dev, test, staging, admin, api: +2
  - Restricted HTTP response such as 401 or 403: +2
  - Server error HTTP response such as 500-599: +2
  - Nmap found at least one open port: +1
  - Normal web ports such as 80, 443, 8080, 8443, 8000 are listed as evidence but do not add extra score when HTTP probing already confirms the web service
  - Risky exposed service such as FTP, SSH, Telnet, SMTP, MySQL, RDP, PostgreSQL, Redis: +3 each
  - Mail-related service such as POP3, IMAP, SMTPS, Submission, IMAPS, POP3S: +2 each
  - Other open port: +1 each
  - More than 5 open ports on same IP: +2
  - More than 10 open ports on same IP: +3

Meaning:
The score is used for exposure prioritization, not as proof of vulnerability. Without Nmap, the score is based on DNS, HTTP, and hostname evidence. With Nmap, open-port evidence is added

==================== FINAL EWRS SUMMARY ====================
Target: khaleejtimes.com

Candidate subdomains collected : 98
DNS resolved assets            : 0
Unresolved candidates          : 0
Unique IP addresses            : 0
Live web services              : 0
Open ports found               : 0
Confirmed findings             : 0
High exposure IPs              : 0
Medium exposure IPs            : 0
Low exposure IPs               : 0
High priority open ports       : 0

Conclusion:
EWRS collected passive and fallback candidates, removed duplicates, validated DNS records, identified unique IPs, checked live web services, applied exposure scoring using all available
```

Figure 6.2: Passive Mode results in EWRS

6.4.2 Active Mode Results

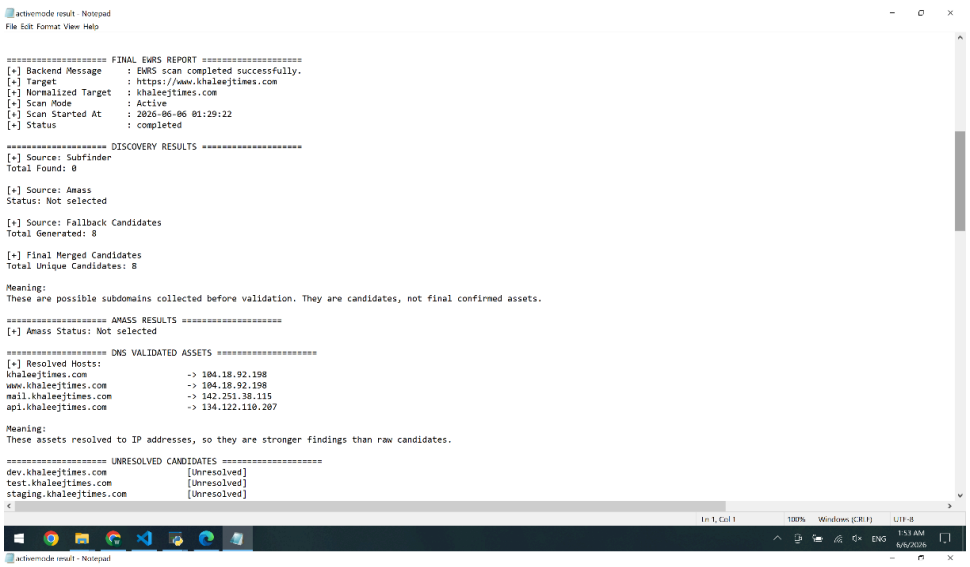
Active Mode was evaluated to observe how EWRS performs validation and checking and in this mode, the framework focuses on DNS validation, HTTP probing, and exposure analysis rather than broad passive discovery.

During the Active Mode test, the target domain was entered as https://www.khaleejtimes.com, and the EWRS normalized it to khaleejtimes.com. The selected modules were Active Validation, DNS Checks, HTTP Probe, and Exposure Analysis and the Passive Recon and Amass Recon were not selected and the output shows that Active Mode did not run Subfinder or Amass and instead, it generated 8 in scope fallback candidates from the target domain.

Out of these 8 candidates, 4 resolved to IP addresses and 4 remained unresolved and the resolved hosts were khaleejtimes.com, www.khaleejtimes.com, mail.khaleejtimes.com, and api.khaleejtimes.com. HTTP probing then identified 4 reachable HTTP/HTTPS services and because the Port Scan module was not selected, no Nmap evidence or open port results were included.

The exposure analysis produced three IP-level exposure results so the two IP addresses were classified as Low exposure and one IP address was classified as Medium exposure and the Medium exposure result was connected to api.khaleejtimes.com, where a sensitive hostname keyword was detected.

This result shows that Active Mode is useful when the purpose is to validate known or generated target candidates and it confirms which assets resolve and which services are live and which externally visible assets may require further review.



activemode result - Notepad
File Edit Format View Help

```
==================== FINAL EWRS REPORT ====================
[+] Backend Message     : EWRS scan completed successfully.
[+] Target              : https://www.khaleejtimes.com
[+] Normalized Target   : khaleejtimes.com
[+] Scan Mode           : Active
[+] Scan Started At     : 2026-06-06 01:29:22
[+] Status              : completed

==================== DISCOVERY RESULTS ====================
[+] Source: Subfinder
Total Found: 0

[+] Source: Amass
Status: Not selected

[+] Source: Fallback Candidates
Total Generated: 8

[+] Final Merged Candidates
Total Unique Candidates: 8

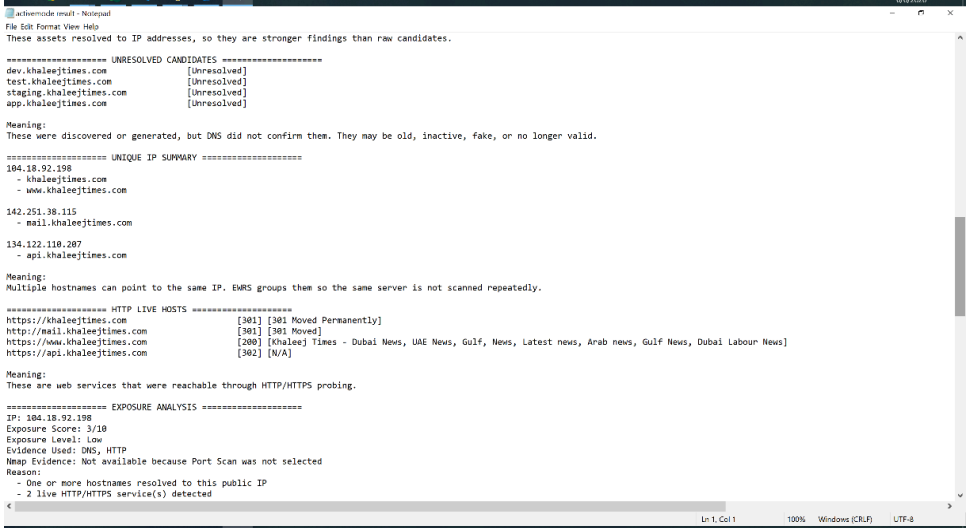
Meaning:
These are possible subdomains collected before validation. They are candidates, not final confirmed assets.

==================== AMASS RESULTS ====================
[+] Amass Status: Not selected

==================== DNS VALIDATED ASSETS ====================
[+] Resolved Hosts:
khaleejtimes.com                -> 104.18.92.198
www.khaleejtimes.com            -> 104.18.92.198
mail.khaleejtimes.com           -> 142.251.38.115
api.khaleejtimes.com            -> 134.122.110.207

Meaning:
These assets resolved to IP addresses, so they are stronger findings than raw candidates.

==================== UNRESOLVED CANDIDATES ====================
dev.khaleejtimes.com            [Unresolved]
test.khaleejtimes.com           [Unresolved]
staging.khaleejtimes.com        [Unresolved]
```



activemode result - Notepad
File Edit Format View Help

```
These assets resolved to IP addresses, so they are stronger findings than raw candidates.

==================== UNRESOLVED CANDIDATES ====================
dev.khaleejtimes.com            [Unresolved]
test.khaleejtimes.com           [Unresolved]
staging.khaleejtimes.com        [Unresolved]
app.khaleejtimes.com            [Unresolved]

Meaning:
These were discovered or generated, but DNS did not confirm them. They may be old, inactive, fake, or no longer valid.

==================== UNIQUE IP SUMMARY ====================
104.18.92.198
  - khaleejtimes.com
  - www.khaleejtimes.com

142.251.38.115
  - mail.khaleejtimes.com

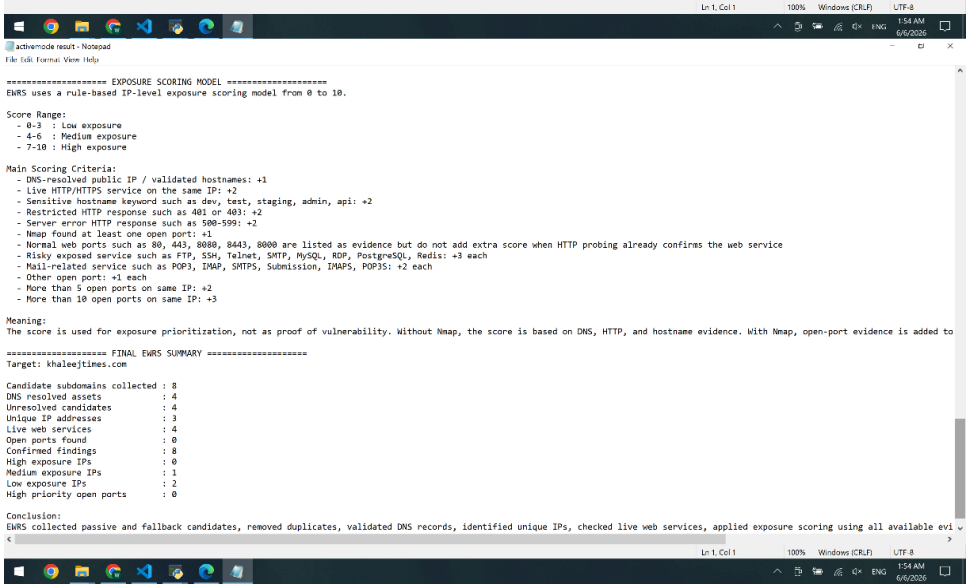
134.122.110.207
  - api.khaleejtimes.com

Meaning:
Multiple hostnames can point to the same IP. EWRS groups them so the same server is not scanned repeatedly.

==================== HTTP LIVE HOSTS ====================
https://khaleejtimes.com                [301] [301 Moved Permanently]
http://mail.khaleejtimes.com            [301] [301 Moved]
https://www.khaleejtimes.com            [200] [Khaleej Times - Dubai News, UAE News, Gulf, News, Latest news, Arab news, Gulf News, Dubai Labour News]
https://api.khaleejtimes.com            [302] [N/A]

Meaning:
These are web services that were reachable through HTTP/HTTPS probing.

==================== EXPOSURE ANALYSIS ====================
IP: 104.18.92.198
Exposure Score: 3/10
Exposure Level: Low
Evidence Used: DNS, HTTP
Nmap Evidence: Not available because Port Scan was not selected
Reason:
  - One or more hostnames resolved to this public IP
  - 2 live HTTP/HTTPS service(s) detected
```



activemode result - Notepad
File Edit Format View Help

```
==================== EXPOSURE SCORING MODEL ====================
EWRS uses a rule-based IP-level exposure scoring model from 0 to 10.

Score Range:
  - 0-3  : Low exposure
  - 4-6  : Medium exposure
  - 7-10 : High exposure

Main Scoring Criteria:
  - DNS-resolved public IP / validated hostnames: +1
  - Live HTTP/HTTPS service on the same IP: +2
  - Sensitive hostname keyword such as dev, test, staging, admin, api: +2
  - Restricted HTTP response such as 401 or 403: +2
  - Server error HTTP response such as 500-599: +2
  - Nmap found at least one open port: +1
  - Normal web ports such as 80, 443, 8080, 8443, 8000 are listed as evidence but do not add extra score when HTTP probing already confirms the web service
  - Risky exposed service such as FTP, SSH, Telnet, SMTP, MySQL, RDP, PostgreSQL, Redis: +3 each
  - Mail-related service such as POP3, IMAP, SMTPS, Submission, IMAPS, POP3S: +2 each
  - Other open port: +1 each
  - More than 5 open ports on same IP: +2
  - More than 10 open ports on same IP: +3

Meaning:
The score is used for exposure prioritization, not as proof of vulnerability. Without Nmap, the score is based on DNS, HTTP, and hostname evidence. With Nmap, open-port evidence is added to

==================== FINAL EWRS SUMMARY ====================
Target: khaleejtimes.com

Candidate subdomains collected : 8
DNS resolved assets            : 4
Unresolved candidates          : 4
Unique IP addresses            : 3
Live web services              : 4
Open ports found               : 0
Confirmed findings             : 8
High exposure IPs              : 0
Medium exposure IPs            : 1
Low exposure IPs               : 2
High priority open ports       : 0

Conclusion:
EWRS collected passive and fallback candidates, removed duplicates, validated DNS records, identified unique IPs, checked live web services, applied exposure scoring using all available evi
```

Figure 6.3: Active Mode results in EWRS

6.4.3 Hybrid Mode Results

Hybrid Mode was evaluated as the most complete workflow in EWRS because it combines passive discovery with active validation and this mode was used to observe how the prototype performs when passive reconnaissance, Amass reconnaissance, DNS validation, HTTP probing, port scanning, exposure analysis and reporting are enabled together.

During the Hybrid Mode test we use to the target domain was entered as www.khaleejtimes.com and EWRS normalized it to khaleejtimes.com and the selected modules included Passive Recon, Amass Recon, Active Validation, DNS Checks, HTTP Probe, Port Scan and Exposure Analysis and this configuration allowed the prototype to run the full reconnaissance workflow from discovery to reporting.

The discovery stage produced results from multiple sources and the Subfinder found 57 results, Amass found 17 results and fallback candidate generation added 8 candidates so after merging the results and removing duplicates and the EWRS produced 65 unique candidate assets and this shows that Hybrid Mode can combine results from different discovery sources and create one cleaner candidate list before validation.

Amass also provided additional relationship based information, including discovered FQDNs, nameservers, IP addresses, CNAME records, netblocks, ASNs and raw relationship output and this helped show that Hybrid Mode can collect not only subdomain names but also supporting external infrastructure metadata so however the report also shows that Amass completed with partial output before timeout which means that runtime and tool timeout remain practical limitations during longer scans.

After discovery the EWRS performed DNS validation and the result shows that 33 assets resolved to IP addresses, while 32 candidates remained unresolved and the EWRS also grouped resolved assets by unique IP address, which is useful because several hostnames can point to the same public IP and this grouping helps reduce repeated analysis of the same server.

HTTP probing identified 12 live web services and these included responses such as 200, 301, 302, 403, and 404 and the Nmap scanning was also enabled and found 40 open ports across resolved IP addresses and the exposure analysis classified 1 IP address as High exposure, 9 IP addresses as Medium exposure, and 11 IP addresses as Low exposure and the final EWRS summary reported 85 confirmed findings and 2 high priority open ports.

This result shows that Hybrid Mode provides the strongest evaluation of the EWRS workflow. Compared with Passive Mode and does not stop at candidate discovery because it validates assets through DNS, HTTP probing, and port scanning and compared with Active Mode, it starts

from a broader discovery stage using Subfinder, Amass, and fallback candidates. Therefore the Hybrid Mode gives the most complete view of externally visible assets and supports the main goal of improving external attack surface visibility.

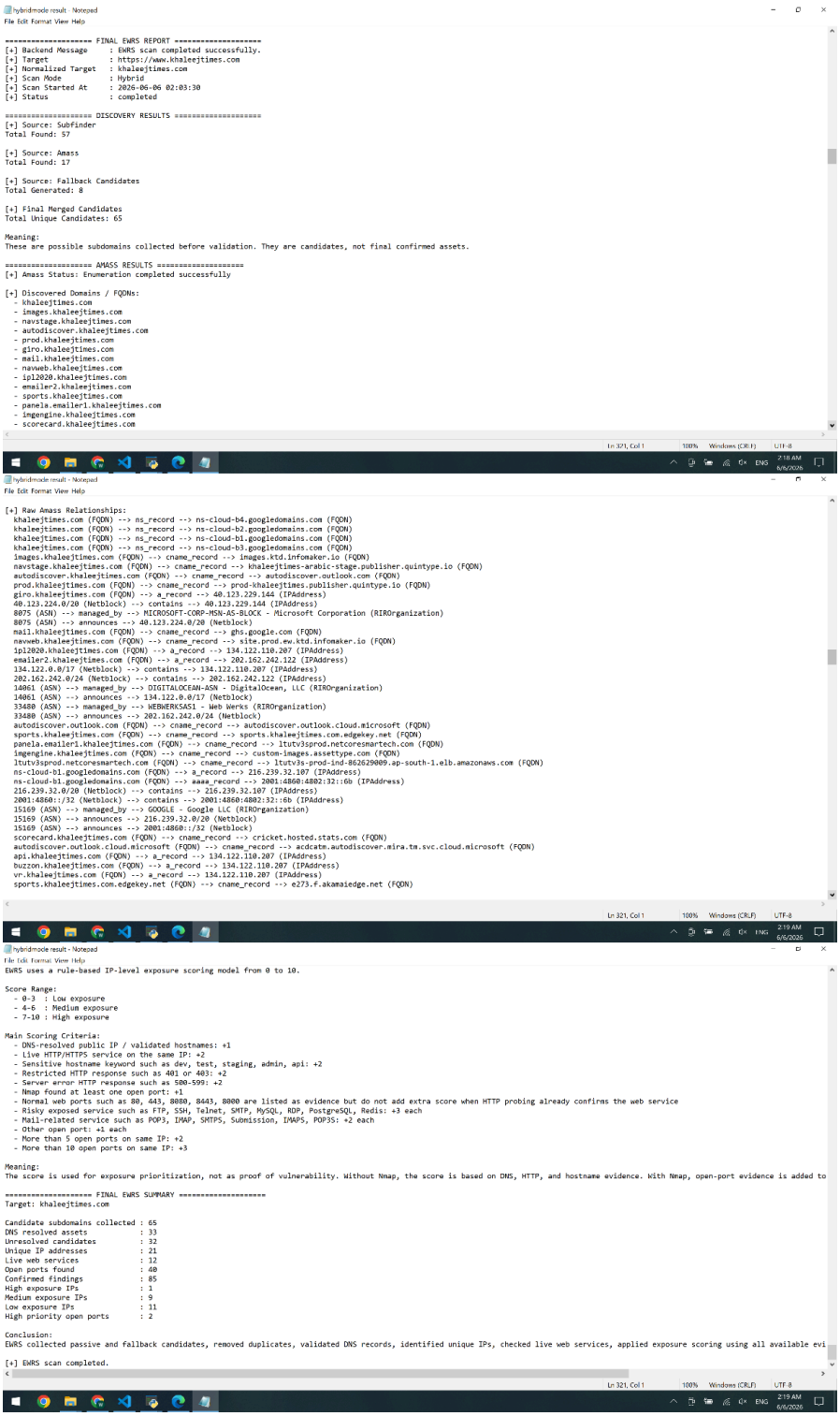


Figure 6.4: Hybrid Mode results in EWRS

6.5 Exposure Scoring Results

Exposure scoring was evaluated to understand that how EWRS prioritizes externally visible assets after discovery and validation and the purpose of the exposure score is not to confirm vulnerabilities but to help identify which public facing assets may need further manual review.

EWRS uses a rule based IP-level scoring model from 0 to 10 and the score is calculated using observable evidence such as DNS resolution, live HTTP/HTTPS responses, sensitive hostname keywords, HTTP status codes, and open port information when Nmap is enabled and the results are then classified into three levels: Low exposure for scores between 0 and 3 and the Medium exposure for scores between 4 and 6 and High exposure for scores between 7 and 10.

In the Active Mode test if we see the EWRS generated preliminary exposure scores because Nmap was not selected and the score was based on DNS, HTTP, and hostname evidence only and the Active Mode result produced 2 Low exposure IPs and 1 Medium exposure IP, while no High exposure IPs were found as we see at the result and the Medium exposure result was caused by a sensitive hostname indicator related to api.khaleejtimes.com and This shows that EWRS can still provide basic prioritization even without port scanning but the score is less complete when Nmap evidence is not available.

If we see in the Hybrid Mode test, the Nmap was selected so open port evidence was included in the exposure scoring and the Hybrid result produced 1 High exposure IP, 9 Medium exposure IPs, and 11 Low exposure IPs and the High exposure result was for IP address 134.122.110.207 which received a score of 10/10 and the reasons included resolved hostnames, live HTTP/HTTPS services, a restricted HTTP response, sensitive hostname indicators, Nmap open port evidence and an exposed SSH service as we see at the picture.

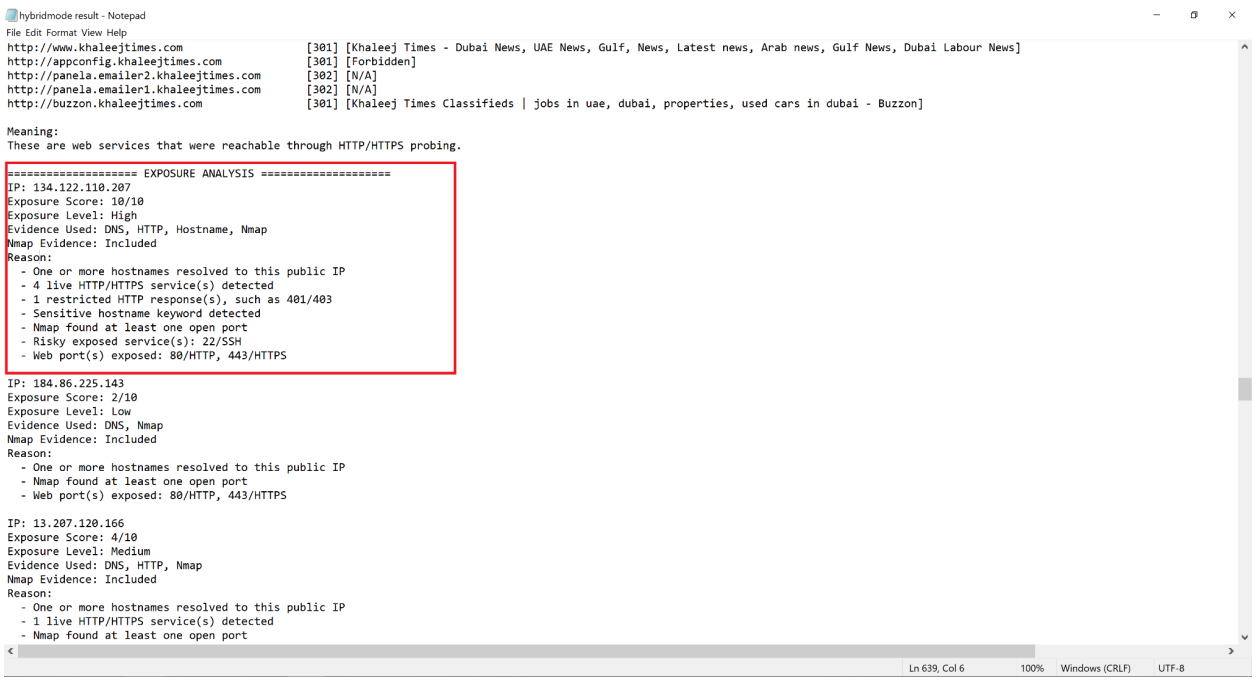


Figure 6.5: High Exposure Result Generated in Hybrid Mode

The Hybrid Mode result also showed 2 high priority open ports and 40 open ports in total and this demonstrates that port scanning adds important evidence to the exposure score and without Nmap, EWRS can only score based on DNS, HTTP and hostname evidence and with Nmap enabled, EWRS can include open ports and service information which makes the scoring more useful for prioritization.

Overall the exposure scoring results show that EWRS can separate assets into different priority levels and the low exposure assets usually have limited observable indicators, Medium exposure assets have stronger evidence such as live web services or additional visible services, and High exposure assets show a stronger combination of indicators and these scores should be treated as prioritization support only not as proof that the asset is vulnerable.

6.6 Manual Tool and EWRS Workflow Comparison

This section compares the manual use of selected reconnaissance tools with their use within the EWRS workflow and the comparison includes Subfinder, Amass, httpx and Nmap, followed by a comparison of the complete reconnaissance workflow. The purpose is not to show that the EWRS replaces these tools, but to examine how their integration into one workflow supports result organization, validation, deduplication, exposure analysis and reporting.

6.6.1 Subfinder: Manual PowerShell Result vs EWRS Result

To compare the manual workflow with EWRS and subfinder was first executed directly in PowerShell using the target domain kust.edu.pk in this manual test, the user had to enter the Subfinder command manually as we see at the screenshot and then read the results directly from the command-line output and the manual Subfinder execution discovered 42 subdomains for the target domain and nothing else will give at the result .



Figure 6.6: Manual Subfinder execution in PowerShell

The same target was then tested using EWRS in Hybrid Mode and in the EWRS result the Subfinder also discovered 42 subdomains for kust.edu.pk and this shows that EWRS was able to execute Subfinder correctly and capture the same Subfinder discovery count as the manual PowerShell execution and therefore at the Subfinder discovery stage and EWRS preserved the same discovery capability as the standalone tool.

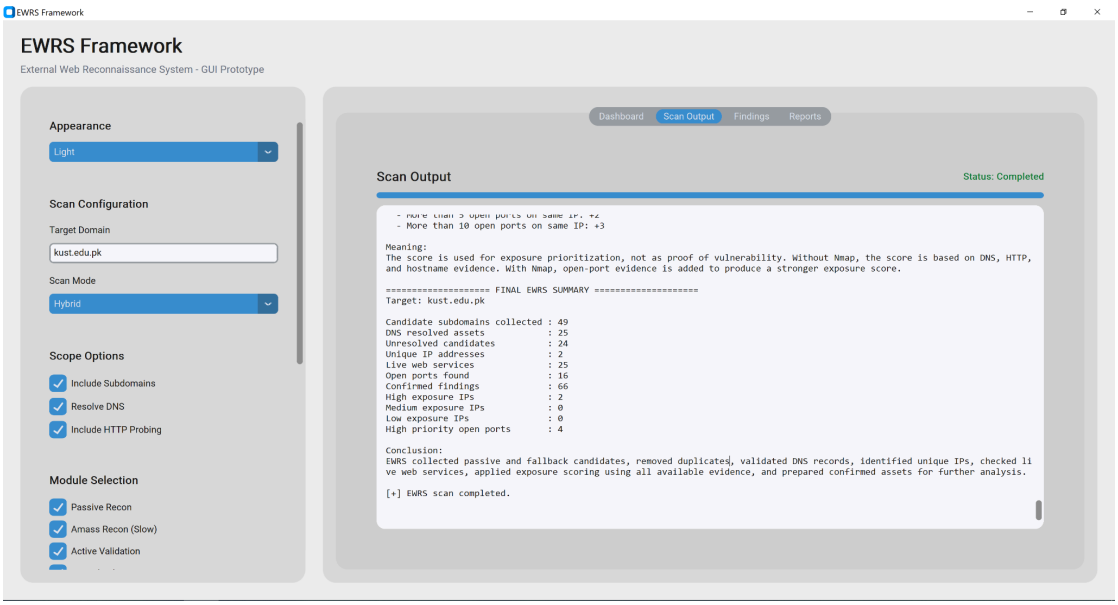


Figure 6.7: Subfinder results integrated into the EWRS Hybrid Mode report

The main difference is how the result is handled after discovery and in the manual PowerShell workflow the Subfinder only provides a raw list of subdomains and nothing else and the user must manually enter the commands and copy the output, save it and then remove duplicates, and run other tools separately for DNS validation, HTTP probing, port scanning and reporting but in EWRS, the Subfinder result is automatically included in the wider reconnaissance workflow.

After collecting the 42 Subfinder results the EWRS also added Amass results and fallback candidates and in the EWRS scan, Amass produced 17 results, fallback generation produced 8 candidates, and after merging and removing duplicates the EWRS produced 49 unique candidate assets and this means that the value 49 in the EWRS summary is not the Subfinder only result and it is the final deduplicated candidate list created from Subfinder, Amass, and fallback candidates.

EWRS continued with the additional validation and analysis steps so the final EWRS report showed that 25 DNS resolved assets and 24 unresolved candidates and also the 2 unique IP addresses as well as the 25 live web services, 16 open ports, 66 confirmed findings and 2 High exposure IPs and these steps are not provided automatically by the standalone Subfinder command.

Table 6.1: Comparison of Manual Subfinder and Subfinder within EWRS

Comparison point	Manual Subfinder in PowerShell	Subfinder inside EWRS
Target	kust.edu.pk	kust.edu.pk
Subfinder result	42 subdomains	42 subdomains
Output format	Raw command line output	Structured inside EWRS report
Command execution	User enters command manually	Tool is executed through EWRS workflow
Additional discovery sources	Not included	Amass and fallback candidates included
Final candidate list	Not generated automatically	49 unique candidates after merging and deduplication
DNS validation	Manual extra step required	25 resolved assets identified
HTTP probing	Manual extra step required	25 live web services identified
Port scanning	Manual extra step required	16 open ports found

Exposure scoring	Not available	2 High exposure IPs identified
Reporting	Manual copy/paste required	Final EWRS report generated automatically

This comparison shows that the EWRS give the same Subfinder discovery result as the manual PowerShell execution for this test and however the EWRS provides a more integrated workflow in this test because it does not stop at a raw subdomain list and it automatically combines Subfinder output with other sources, removes duplicates, validates assets, identifies live services, scans ports, applies exposure scoring and generates a structured report.

6.6.2 Amass: Manual PowerShell Result vs EWRS Result

To compare Amass in the manual workflow and EWRS workflow, Amass was first executed directly in PowerShell for the target manwithvan.ae and in the manual PowerShell output, Amass showed a raw relationship result, mainly showing that manwithvan.ae had an MX-related relationship and this confirms that Amass can collect external asset relationship information, but the result is displayed as raw terminal output and must be interpreted manually by the user.

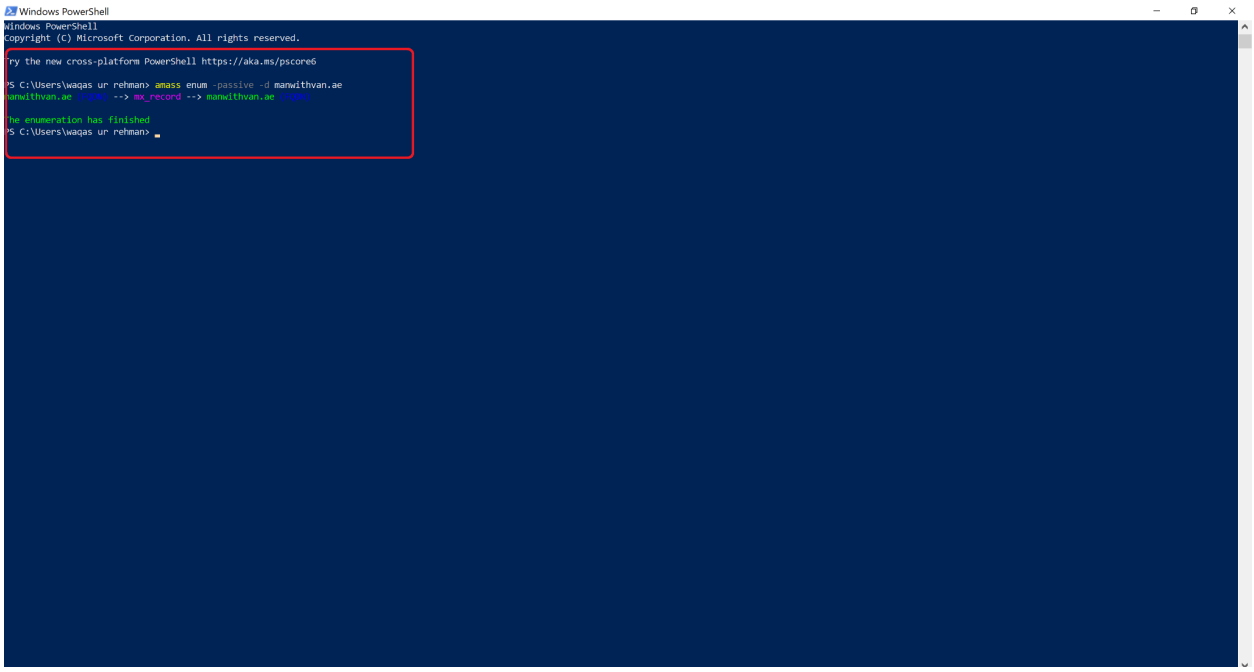


Figure 6.8: Manual Amass execution in PowerShell

The same target was then tested using EWRS in Hybrid Mode and in EWRS, Amass was executed as part of the wider reconnaissance workflow. EWRS captured the Amass output and organized it into clear report sections and instead of showing only raw relationship lines, EWRS separated the information into discovered domains/FQDNs, nameservers, mail records, IP addresses, CNAME records, netblocks, ASNs and raw Amass relationships.

For manwithvan.ae the EWRS showed that Amass identified the domain manwithvan.ae, the nameservers dns1.hosterpk.com and dns2.hosterpk.com, mail record information, the IP address 64.31.43.34, the netblock 64.31.43.0/24 and the ASN 46475 and these details were presented in separate sections, which made the Amass output easier to understand and use in the final report.

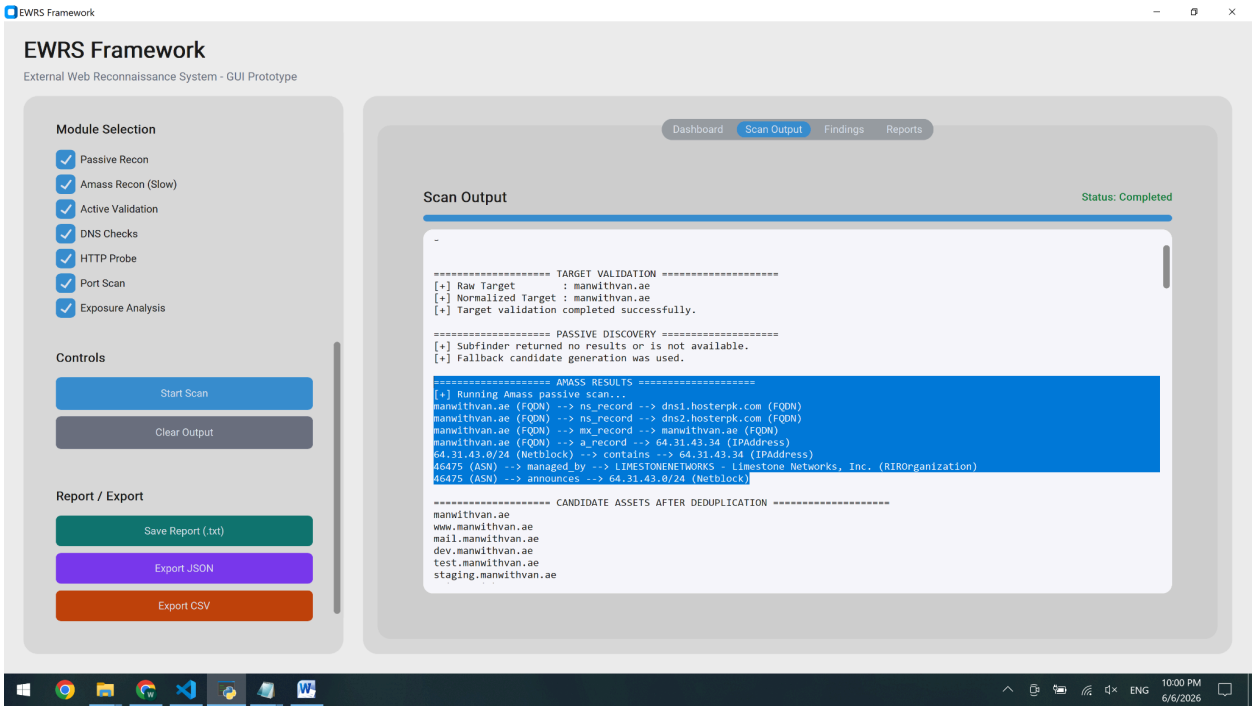


Figure 6.9: Amass results organized inside the EWRS report

The comparison shows that manual Amass provides useful raw relationship data but EWRS improves how that data is processed and presented and in the manual workflow, the user must read and interpret the raw Amass output and in EWRS, the same type of information is automatically structured into meaningful categories and This improves readability and reduces the manual effort needed to prepare the results for reporting.

Table 6.2: Comparison of Manual Amass and Amass within EWRS

Comparison point	Manual Amass in PowerShell	Amass inside EWRS
Target	manwithvan.ae	manwithvan.ae
Execution	User runs Amass manually	Amass runs inside EWRS Hybrid Mode
Output format	Raw terminal relationship output	Structured EWRS report
Discovered FQDNs	Shown as raw relationship lines	Listed clearly under Discovered Domains / FQDNs
Nameservers	User must identify manually from raw output	Listed clearly under Nameservers
Mail records	Shown as raw MX relationship	Listed clearly under Mail Records
IP addresses	User must identify manually if shown	Listed clearly under IP Addresses
Netblocks	Not clearly separated in manual output	Listed clearly under Netblocks

ASNs	Not clearly separated in manual output	Listed clearly under ASNs
Raw relationships	Displayed directly in terminal	Preserved under Raw Amass Relationships
Followup processing	Must be done manually	Continued automatically with DNS, HTTP, Nmap, scoring, and reporting
Usability	Requires manual interpretation	Easier to read, compare, and include in report

The Amass comparison shows that EWRS improves the usability of Amass output and manual Amass provides useful raw relationship information but EWRS organizes the result into clear categories such as FQDNs, nameservers, mail records, IP addresses, netblocks, ASNs, and raw relationships and therefore the EWRS adds value by transforming raw Amass output into structured external asset information that is easier to understand and include in the final reconnaissance report.

6.6.3 httpx: Manual PowerShell Result vs EWRS Result

To compare HTTP probing in the manual workflow and EWRS workflow, httpx was first executed directly in PowerShell for the target manwithvan.ae in the manual test, httpx checked the HTTP/HTTPS availability of the target and displayed the results in the terminal and the manual output showed reachable web services, HTTP status codes, page title information and IP address information.

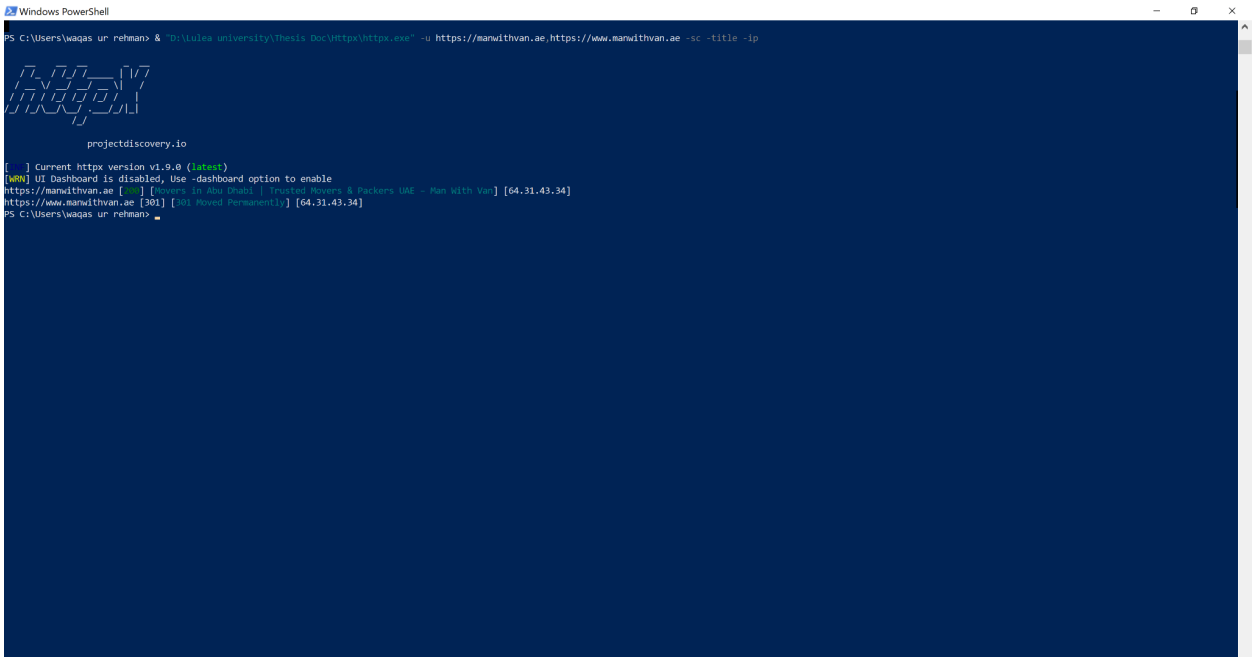


Figure 6.10: Manual httpx execution in PowerShell

The manual httpx result is useful because it confirms which web services are reachable. However, the result remains as raw terminal output and if the user wants to use this information in a report the output must be copied, cleaned, and interpreted manually.

In EWRS the httpx is integrated into the Hybrid Mode workflow and after candidate assets are collected and DNS validation is completed,the EWRS uses HTTP probing to identify live web services. For manwithvan.ae and the EWRS identified three live web services: www.manwithvan.ae, mail.manwithvan.ae, and manwithvan.ae and the report also showed the HTTP response status codes and page titles for these live web services.

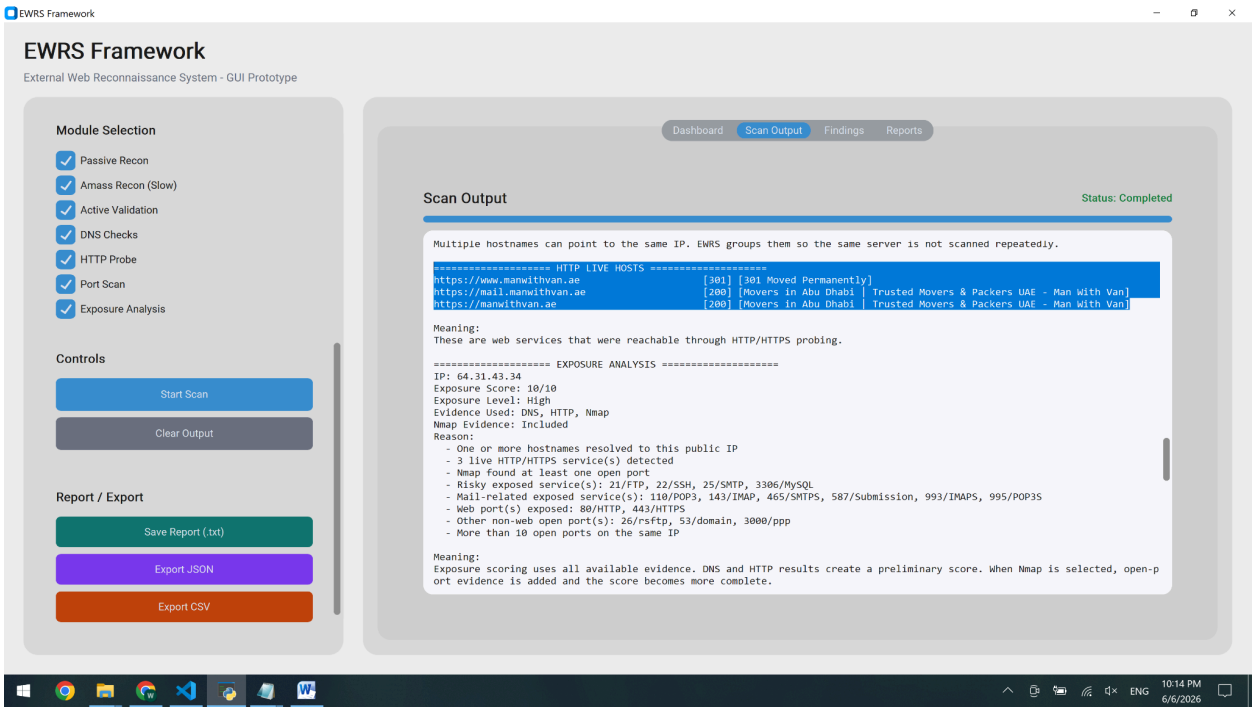


Figure 6.11: httpx results integrated into the EWRS report

The main advantage of EWRS is that the httpx result is not treated as a separate output. Instead, it is connected to the full reconnaissance workflow and the HTTP results are placed in the final report and used as evidence in exposure scoring and connected with DNS validation and Nmap results and this makes the HTTP probing result easier to understand and more useful for prioritization.

Table 6.3: Comparison of Manual httpx and httpx within EWRS

Comparison point	Manual httpx in PowerShell	httpx inside EWRS
Target	www.manwithvan.ae	manwithvan.ae and generated candidates
Execution	User runs httpx manually	httpx runs inside EWRS Hybrid Mode

Output format	Raw terminal output	Structured EWRS report
HTTP status codes	Displayed in terminal	Listed under HTTP Live Hosts
Page titles	Displayed in terminal	Included in the EWRS report
IP information	Displayed if selected in command	Connected with DNS and unique IP summary
Follow-up processing	Must be done manually	Connected to exposure scoring
Reporting	Manual copy/paste required	Included automatically in final report
Usability	Useful but separate output	Easier to read and connected with other findings

The httpx comparison shows that both manual httpx and EWRS can identify reachable HTTP/HTTPS services. However, EWRS improves the use of httpx output by placing the results inside a structured workflow. In EWRS, HTTP probing results are connected with DNS validation, Nmap scanning, exposure scoring, and reporting so therefore, EWRS makes the httpx output more useful for external asset visibility and prioritization.

6.6.4 Nmap: Manual PowerShell Result vs EWRS Result

To compare port scanning in the manual workflow and EWRS workflow Nmap was first executed directly in PowerShell for the target manwithvan.ae. In the manual test, the Nmap scanned the resolved IP address 64.31.43.34 and displayed the open ports directly in the terminal

and the manual result showed several open services, including FTP, SSH, SMTP, DNS, HTTP, POP3, IMAP, HTTPS, SMTPS, Submission, IMAPS, POP3S and other open ports.

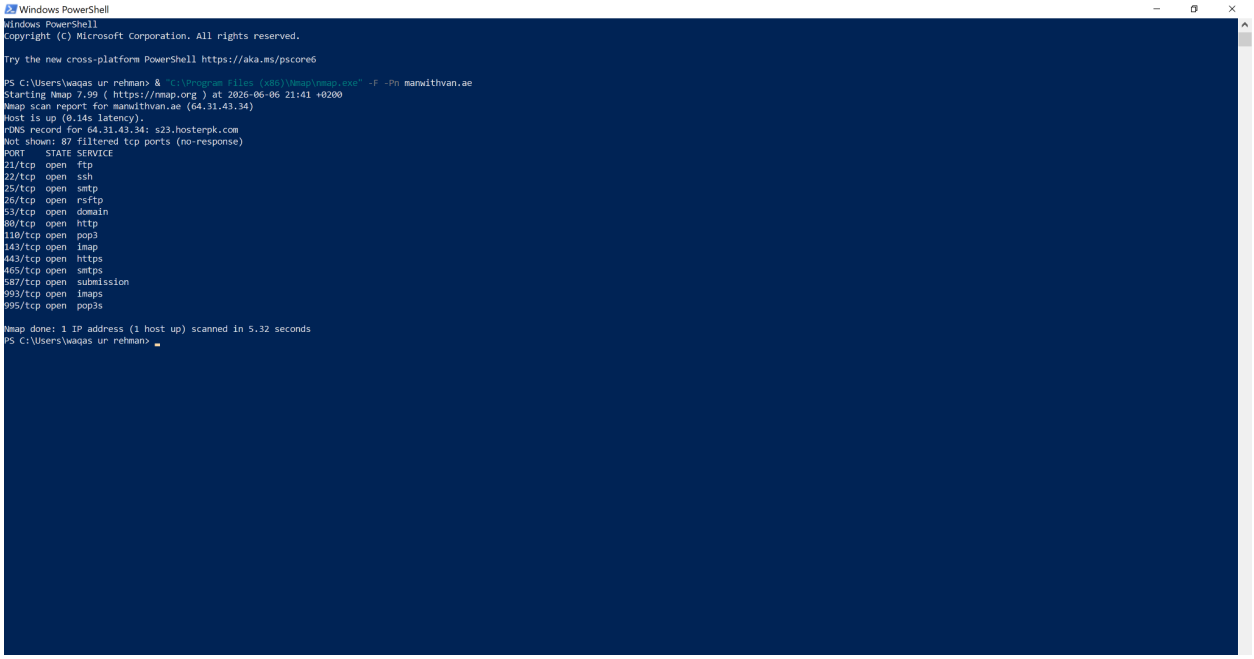


Figure 6.12: Manual Nmap execution in PowerShell

The manual Nmap result is technically useful because it identifies open ports and services. However, the output remains a raw terminal result and the user must manually decide which ports are more important, which services may require review and how the result should be written in a report.

In EWRS,the Nmap is integrated into the Hybrid Mode workflow and after DNS validation identifies the resolved IP address and the EWRS runs Nmap and includes the results in the final report. For manwithvan.ae, EWRS scanned 64.31.43.34 and found 15 open ports, including FTP, SSH, SMTP, DNS, HTTP, POP3, IMAP, HTTPS, SMTPS, Submission, IMAPS, POP3S, port 3000 and MySQL.

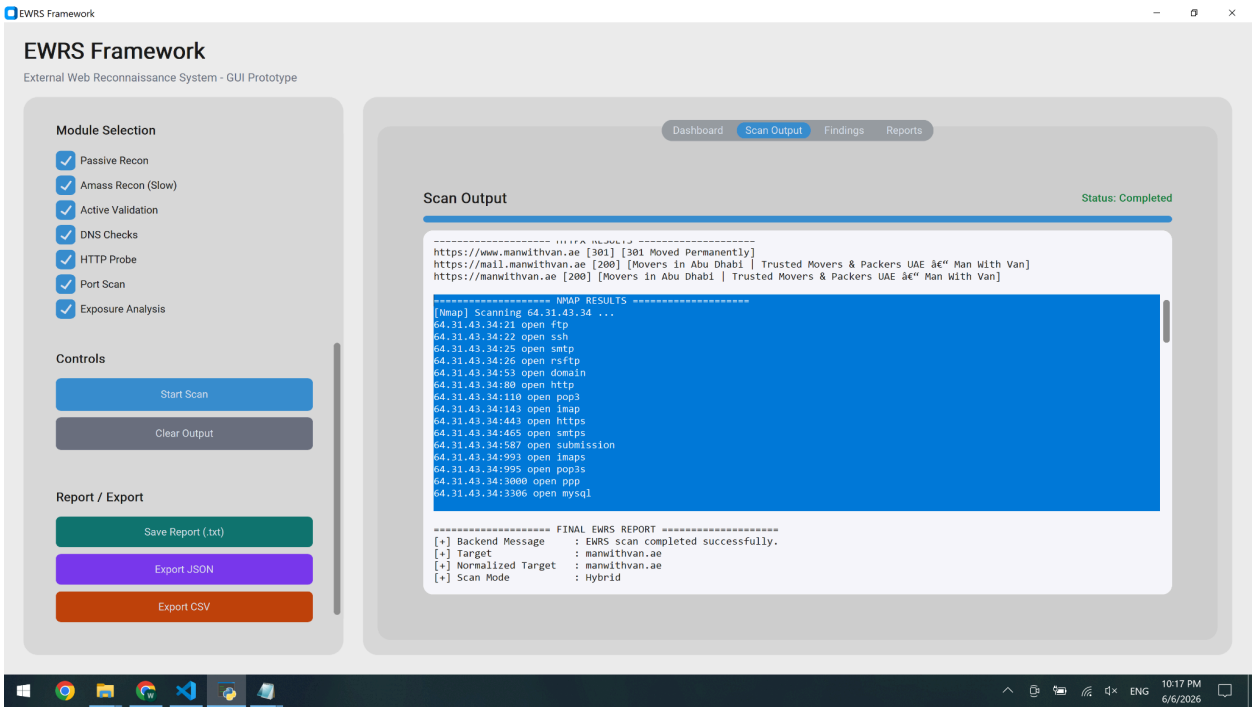


Figure 6.13: Nmap results integrated into the EWRS report

The main improvement in EWRS is that Nmap results are not only shown as raw open ports. EWRS groups the ports under the related IP address, connects the IP address with its hostnames, assigns port priority levels, and uses the openport evidence in the exposure scoring model and in this test the EWRS classified 64.31.43.34 as High exposure with a score of 10/10 and the report also identified 4 high-priority open ports and explained the reason for the score, including risky exposed services such as FTP, SSH, SMTP, and MySQL as well as multiple mail related services.

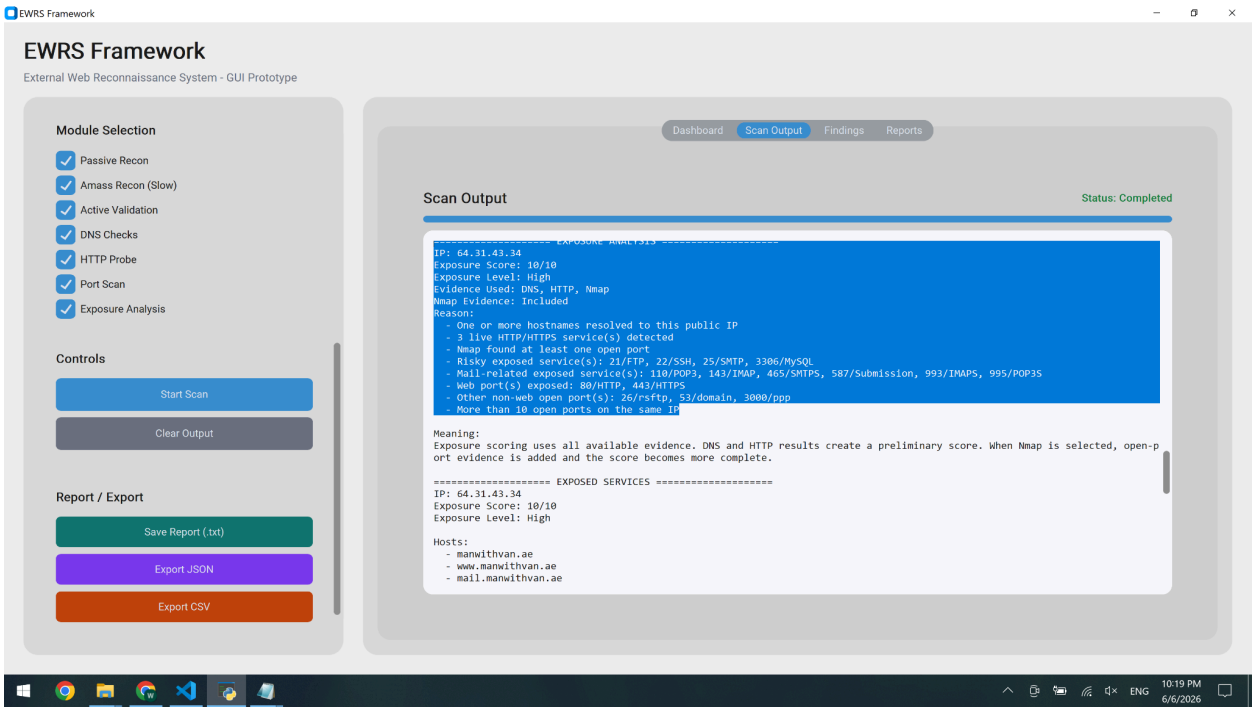


Figure 6.14: Nmap Exposure Analysis and Prioritized Services in EWRS

Table 6.4: Comparison of Manual Nmap and Nmap within EWRS

Comparison point	Manual Nmap in PowerShell	Nmap inside EWRS
Target	manwithvan.ae / 64.31.43.34	Resolved IP 64.31.43.34 from EWRS workflow
Execution	User runs Nmap manually	Nmap runs inside EWRS Hybrid Mode
Output format	Raw terminal port list	Structured EWRS report

Open ports	Displayed in terminal	Listed under Nmap results and exposed services
Hostname relation	User must interpret manually	Hostnames grouped with the IP address
Port priority	Not provided automatically	Priority labels added for services
Exposure scoring	Not available	IP classified as High exposure, 10/10
High-priority services	Must be identified manually	4 highpriority open ports identified
Reporting	Manual copy/paste required	Included automatically in final report
Usability	Useful technical scan output	Organized, prioritized and connected to findings

The Nmap comparison shows that both manual Nmap and EWRS can identify open ports and services. However the EWRS improves the result by connecting Nmap output with DNS validation, hostname grouping, exposed service analysis, port priority and exposure scoring and therefore the EWRS makes Nmap results easier to understand and more useful for prioritizing externally visible services.

6.6.5 Full Workflow Comparison

After comparing the Subfinder discovery stage the next comparison focuses on the complete reconnaissance workflow and in a manual workflow, the user must run each tool separately and for example,the Subfinder is used for subdomain discovery, Amass is used for additional asset discovery, DNS checks are performed separately, httpx is used for HTTP/HTTPS probing and Nmap is used for port scanning and after running these tools and the user must manually

combine the outputs and then remove duplicate results, identify resolved and unresolved assets, group hostnames by IP address, interpret open ports and prepare the final report.

In EWRS these steps are combined into one automated workflow and the user enters the target domain once and selects the scan mode and modules and the EWRS prototype executes the selected stages in order and for the kust.edu.pk the Hybrid Mode test, EWRS collected Subfinder results, Amass results, and fallback candidates then merged and deduplicated them into 49 unique candidate assets and after this the EWRS performed DNS validation, HTTP probing, Nmap port scanning, exposure scoring, and report generation.

The final EWRS summary showed 25 DNS resolved assets and 24 unresolved candidates and also the 2 unique IP addresses, 25 live web services, 16 open ports, 66 confirmed findings, 2 High exposure IPs, and 4 high priority open ports and these results show that EWRS does not only collect raw discovery data and it also validates, organizes, prioritizes and reports the results in a structured way.

Table 6.5: Comparison of Manual Multi-Tool Workflow and EWRS Workflow

Evaluation point	Manual multi tool workflow	EWRS workflow
Target input	Enter target separately in each tool	Enter target once in the GUI
Subdomain discovery	Run Subfinder manually	Subfinder integrated

Additional asset discovery	Run Amass manually	Amass integrated
Fallback candidates	Must be created manually	Generated automatically
Deduplication	Manual comparison required	Automatic merging and deduplication
DNS validation	Separate manual step	Integrated DNS validation
HTTP probing	Run httpx manually	Integrated HTTP probing
Port scanning	Run Nmap manually	Integrated Nmap scanning
IP grouping	Manual grouping required	Hostnames grouped by unique IP
Exposure analysis	Manual interpretation required	Rule based exposure scoring
Reporting	Manual copy/paste and formatting	Final EWRS report generated
Final result	Separate raw outputs	Structured discovery, validation, scoring, and report output

The comparison shows that, in the tested workflow, EWRS provided a more integrated approach for executing and organizing the selected reconnaissance stages than running the tools separately

because it reduces manual work and improves result organization and the individual tools are still important, but EWRS connects them into one structured process and this means the user does not need to manually move from one tool to another and combine results by hand and instead, the EWRS creates a clearer output that includes discovered candidates, validated assets, live services, open ports, exposure levels, and a final report.

Therefore the main contribution of EWRS is workflow improvement and it does not replace the tools such as Subfinder, Amass, httpx, or Nmap and instead it integrates them and adds automation, deduplication, validation, exposure scoring and reporting so this supports the thesis goal of improving external attack surface visibility through a more organized reconnaissance process.

6.7 Mapping Findings to Research Questions

This section maps the evaluation findings directly to the main research question and subresearch questions and the purpose is to show how the EWRS prototype addresses the research problem and how the evaluation results support the answers.

Research question	Evidence from evaluation	Answer / finding
MRQ: How can an automated framework that combines the active and passive web reconnaissance improve external attack surface visibility compared to using separate tools manually?	EWRS combined passive discovery, Amass reconnaissance, fallback candidates, DNS validation, HTTP probing, Nmap scanning, exposure scoring, and reporting in one workflow. In the KUST test, EWRS produced 49 unique candidate assets, 25 DNS resolved assets, 25 live web services, 16 open ports, and 2 High exposure IPs.	EWRS helps by connecting separate reconnaissance tasks into one automated workflow. Instead of running tools one by one and manually combining the outputs, EWRS collects, merges, validates, organizes, scores, and reports the results and this improves reliability because candidate assets are not only discovered but also validated through DNS, HTTP probing, and port scanning.

SRQ1: What are the biggest problems with current reconnaissance tools and methods that make reconnaissance incomplete or unreliable (DNS, subdomains, directories etc.) ?	The manual tool comparison showed that tools such as Subfinder, Amass, httpx, and Nmap produce separate outputs and manual use requires the user to copy outputs, remove duplicates, run additional validation and interpret results separately. Some tools may also return no result for a target, such as Subfinder returning no subdomains for some domains.	The main problems are fragmentation, manual effort, duplicate results, unvalidated discovery results and inconsistent output formats and a single tool may only cover one part of reconnaissance and for example the subfinder can discover subdomains but it does not confirm live services or open ports by itself.
SRQ 2 : How much more verified information (unique live assets) can we find when we combine passive sources like CT logs with active probing and enumeration?	In the KUST test, Subfinder discovered 42 subdomains. EWRS then combined Subfinder with Amass and fallback candidates, producing 49 unique candidate assets. After active validation the EWRS identified 25 DNS resolved assets, 25 live web services, 2 unique IP addresses, and 16 open ports.	Combining passive and active methods gives more useful verified information than passive discovery alone and passive discovery creates candidate assets, but active validation confirms which assets resolve, which web services are live, and which ports are exposed and this makes the result stronger and more useful for security review.
SRQ3: How much does automation reduce manual work and improve consistency (less duplication, clearer results) compared to running tools one-by-one?	In the manual workflow, each tool had to be executed separately in PowerShell and the user then had to manually interpret Subfinder, Amass, httpx, and Nmap outputs and in EWRS, the same types of results were collected in one report, with automatic deduplication, DNS validation, IP grouping,	Automation reduces manual work by removing the need to run every command separately and combine outputs by hand and it improves the consistency because the EWRS follows the same workflow each time target validation, discovery, deduplication, DNS checking, HTTP probing, port scanning, exposure scoring, and reporting.

	exposure scoring, and report generation.	

Overall the evaluation shows that EWRS addresses the problem of fragmented web reconnaissance and the framework does not replace tools such as Subfinder, Amass, httpx, and Nmap and instead, it integrates them into one structured workflow and adds result processing, validation, prioritization, and reporting and this makes the reconnaissance process more organized and helps the user move from raw tool outputs to verified and prioritized external asset information.

6.8 Summary

This chapter presented the evaluation and results of the EWRS prototype and the evaluation was carried out using selected target domains and different scan modes to observe how EWRS performs discovery, validation, port scanning, exposure scoring and reporting.

The results showed that Passive Mode is useful for collecting candidate assets, Active Mode is useful for validation and checking, and Hybrid Mode provides the most complete workflow because it combines passive discovery with active validation and if we see in the KUST test, EWRS collected 49 unique candidate assets, identified 25 DNS resolved assets, detected 25 live web services, found 16 open ports and classified 2 IP addresses as High exposure and this showed how EWRS can move from raw discovery to verified and prioritized external asset information.

The tool-by-tool comparison showed that individual tools such as Subfinder, Amass, httpx, and Nmap are useful but they normally produce separate outputs and the EWRS improves this process by integrating these tools into one workflow and adding deduplication, DNS validation, IP grouping, exposure scoring, and structured reporting.

The chapter also mapped the evaluation findings directly to the main research question and sub research questions and the findings showed that EWRS addresses the problem of fragmented reconnaissance by combining passive and active techniques in one framework and it does not replace existing tools, but improves how their outputs are connected, organized, validated, and reported.

Overall, the evaluation shows that EWRS supports the thesis objective of improving external web reconnaissance and external attack surface visibility through a structured automated workflow.

Chapter 7

Discussion

7.1 Introduction

This chapter discusses the main findings from the design, implementation and evaluation of EWRS and while the previous chapter presented the evaluation results this chapter explains what those results mean in relation to the research problem and research questions.

The purpose of EWRS was to improve external web reconnaissance by combining passive discovery, active validation, port scanning, exposure analysis and reporting in one structured workflow so the previous work has shown that using multiple reconnaissance tools separately can make the reconnaissance process cumbersome and time consuming and less efficient which supports the need for a more integrated workflow [18].The research on automated OSINT and digital asset discovery also shows that automation can help organizations process public asset information more efficiently and support external visibility and risk assessment activities[19].

The discussion focuses on how EWRS addresses the problem of fragmented reconnaissance and how it supports external attack surface visibility and what limitations were observed during testing and the chapter also discusses the exposure scoring model used in EWRS so the scoring model is used for prioritization of externally visible assets not as proof of confirmed vulnerabilities and this distinction is important because formal vulnerability scoring systems such as CVSS are intended for communicating characteristics of known vulnerabilities and while EWRS uses observable reconnaissance evidence to support prioritization[20]

This chapter also explains the contribution of the thesis to knowledge and practice and the contribution is not the creation of a new reconnaissance scanner from the beginning and instead and the contribution is the design and evaluation of an integrated workflow that connects existing reconnaissance tools and adds structure, validation, prioritization and reporting.

7.2 Discussion of Evaluation Findings

The evaluation results show that EWRS can support external web reconnaissance by combining discovery, validation, service checking, exposure scoring and reporting in one workflow and the results also show that each scan mode has a different role and the passive Mode is useful for collecting possible external assets and the Active Mode is useful for validating known or generated candidates and Hybrid Mode provides the most complete workflow because it

combines passive discovery and active validation and the previous research also distinguishes active, passive and hybrid approaches to asset discovery, where hybrid scanning combines passive observation with active techniques to obtain useful asset information [37].

One important finding is that passive discovery alone is not enough to confirm whether an asset is active or reachable and the passive sources may discover candidate domains or subdomains but some of these assets may be inactive, outdated, duplicated or unresolved and this is consistent with the broader challenge in external asset discovery where the public OSINT sources can provide a useful visibility but still require processing, validation and correlation before they become reliable security information[19].So therefore the EWRS combines passive discovery with DNS validation, HTTP probing and port scanning to separate a stronger findings from raw candidates.

Hybrid Mode addressed this issue by combining the Subfinder, Amass, fallback candidates, DNS validation, HTTP probing, Nmap scanning and exposure analysis if we see in the KUST evaluation the EWRS collected 49 unique candidate assets after merging and deduplication and it then identified 25 DNS resolved assets, 25 live web services, 2 unique IP addresses and 16 open ports, 66 confirmed findings and 2 High exposure IPs so these results show how EWRS moves from raw discovery to verified and prioritized external asset information.

The evaluation also showed the importance of result organization and when tools are used manually the each tool produces a separate output and the subfinder provides subdomains, Amass provides asset relationships, httpx provides HTTP response information and Nmap provides open port information and these outputs are useful but they require manual interpretation and combination and if we see the previous work on consolidating reconnaissance tools also identifies that using multiple tools individually can be cumbersome and time consuming which supports the need for a unified workflow [18]. Similarly the Boyanov presents a structured reconnaissance methodology that combines multiple specialized tools within one integrated workflow and shows that this approach can provide a more complete network asset profile than using the tools separately [38] .The EWRS improves this process by organizing outputs into clear sections such as discovered candidates, DNS validated assets, unresolved candidates, unique IP summary, HTTP live hosts, exposed services, exposure analysis and final summary.

Another important finding is that fallback candidate generation improves workflow continuity and if we see in the manwithvan.ae test the Subfinder returned no subdomain results but EWRS did not stop there and it continued by using fallback candidates, Amass output, DNS validation, HTTP probing, Nmap scanning and exposure scoring so this shows that EWRS is more reliable than depending on one discovery source only and if one tool returns no result the workflow can still continue using other available evidence.

The exposure scoring result also helped prioritize assets for review and in the manwithvan.ae test the EWRS classified the IP address 64.31.43.34 as High exposure with a score of 10/10 because it had resolved hostnames, live HTTP/HTTPS services, Nmap openport evidence, risky exposed services, mail-related services and more than ten open ports so this does not prove that the asset is vulnerable but if we see it provides a structured way to identify which externally visible assets may need further manual security review and this distinction is important because formal scoring systems such as CVSS are designed for known vulnerabilities[20] and while EWRS uses observable reconnaissance evidence only for exposure prioritization.

7.3 Contribution to Knowledge and Practice

This thesis contributes to knowledge by demonstrating how passive and active web reconnaissance techniques can be combined into one structured framework and existing reconnaissance tools are useful but they are often used separately and produce outputs in different formats so if we see the previous work has also highlighted that using multiple reconnaissance tools individually can be cumbersome, time consuming which supports the need for a more integrated reconnaissance workflow[18] and the EWRS addresses this problem by showing how different reconnaissance stages can be connected into one workflow so the passive discovery, active validation, HTTP probing, port scanning, exposure scoring and reporting.

From a Design Science Research perspective, the contribution of this thesis is the design of the EWRS framework and the development and evaluation of its software prototype as a research artifact [13,14]. In this thesis the EWRS was designed to address the practical problem of fragmented external web reconnaissance and the evaluation showed how the artifact works in different scan modes and how it supports the movement from raw discovery results to validated and prioritized external asset information.

The thesis also contributes by presenting a simple exposure scoring model for prioritizing externally visible assets and the scoring model does not claim to identify confirmed vulnerabilities and instead it uses observable technical indicators such as DNS resolution live HTTP/HTTPS response, sensitive hostname keywords, HTTP status codes and exposed network services and this provides a practical way to prioritize assets for further manual security review and the distinction between exposure prioritization and formal vulnerability scoring is important because CVSS is designed for communicating the characteristics and severity of known vulnerabilities while EWRS focuses on reconnaissance evidence and asset exposure[20].

EWRS also contributes to practice by improving result readability and the tool-by-tool comparison showed that manual tools provide useful technical outputs but these outputs require manual interpretation and the EWRS keeps the value of the individual tools while presenting their outputs in a more structured and understandable way and this can help security students, junior analysts and security practitioners review external asset information more efficiently.

7.4 Limitations of EWRS

Although the evaluation showed that EWRS can support external web reconnaissance the prototype also has several limitations and these limitations are important because EWRS was developed as a research prototype not as a complete commercial external attack surface management platform so the the current version demonstrates the feasibility of integrating passive discovery, active validation, HTTP probing, port scanning, exposure scoring and reporting but more work is still needed to make the framework stronger and more scalable as well as easier to use.

One limitation is tool dependency and the EWRS depends on external tools such as Subfinder, Amass, httpx, and Nmap and if one of these tools is not installed correctly, not available in the system path, blocked by the operating environment, or unable to return results, the quality of the scan output can be affected and this type of limitation is common in tool based reconnaissance workflows because each tool has its own data sources, command format, execution behavior, and output style and the previous work on consolidating reconnaissance tools also shows that using multiple reconnaissance tools separately can be cumbersome and time consuming which supports the need for integration but also shows that the tool dependency remains a practical challenge [18].

Another limitation is that passive reconnaissance results can vary between scans and the Passive tools depend on external data sources such as public datasets, certificate information, DNS records, OSINT sources, and third party providers and these sources may change over time, may be incomplete, or may not contain the same amount of information for every target so for example the Certificate Transparency logs can reveal DNS names and support subdomain discovery but they only show information that appears in logged certificates and may also create information leakage concerns [21] so therefore the passive discovery results should be treated as candidate assets until they are validated.

A further limitation is that discovery results do not automatically mean that an asset is live, active, or security relevant so the candidate subdomains may be old, inactive, duplicated, parked, unresolved, or related to third party infrastructure.The EWRS partly addresses this by separating discovered candidates from DNS resolved assets and live web services . However the current version still needs better filtering to reduce noise and improve result accuracy and the previous work on subdomain enumeration and information scraping also shows that discovered

subdomains need validation through DNS resolution or active checks before they can be treated as operational or useful assets [22].

Execution time is another limitation so some modules, especially Amass and Nmap can take longer to complete depending on the target domain, network conditions, number of candidate assets and selected scan configuration and in some cases the Amass may produce partial output before timeout and this means that timeout handling, progress tracking and large scale scan management need more improvement and automated OSINT research also highlights that scalability, processing performance and handling heterogeneous data sources are important challenges in automated asset discovery systems [19].

Another limitation is the integration of EWRS into real organizational environments and the current prototype was developed and tested as a standalone research application while real organizational environments may contain heterogeneous systems, security tools, network configurations and different data sources so the previous research shows that integrating security technologies in such environments can introduce challenges related to heterogeneous hardware and software, incompatible data formats, tool interoperability, configuration requirements and access control [28,29]. External tools such as Subfinder, Amass, httpx and Nmap must also be installed and configured correctly before EWRS can use them. In a real environment the integration may therefore require additional configuration, access permissions, tool compatibility checks and adaptation to the existing security workflow [28,30]. The larger deployments may also require scalable orchestration, centralized processing, persistent data storage and continuous monitoring which are not included in the current EWRS prototype [28,30].

EWRS also does not confirm vulnerabilities and the EWRS prototype identifies externally visible assets, live web services, open ports and exposure indicators but it does not exploit systems or verify whether a specific vulnerability exists and the exposure score is therefore only a prioritization score and it should not be understood as a confirmed vulnerability score and this distinction is important because CVSS is designed for communicating the characteristics and severity of known vulnerabilities while EWRS uses observable reconnaissance evidence for exposure prioritization [20] and therefore the EWRS results should be followed by manual review or more detailed vulnerability assessment where authorization is available.

Another limitation is the limited number of integrated tools and the current EWRS prototype includes Subfinder, Amass, httpx, and Nmap, which are useful for discovery, validation, HTTP probing, and port scanning. However the framework could become stronger by adding more tools and modules so for example the future versions could include Certificate Transparency log collection, MassDNS for faster DNS resolution and Nuclei for template based vulnerability checks and WhatWeb or Wappalyzer style technology detection, TLS/certificate analysis, directory enumeration, screenshot capture etc and continuous monitoring and adding more tools

would increase coverage and help EWRS provide a more complete view of externally visible assets.

EWRS currently focuses on external reconnaissance and exposure prioritization and this means that it only checks information that is visible from outside such as domains, subdomains, DNS resolution, live HTTP/HTTPS services, open ports, and exposure indicators and it does not include authenticated testing, confirmed vulnerability verification, web crawling, directory brute forcing, database storage, historical scan comparison, or scheduled monitoring and these features were outside the scope of this thesis but they are important for future development. The recent research on automated OSINT supports the value of richer public data sources, automated classification, and continuous asset visibility [19] and in addition the AI assisted asset discovery research shows that future systems may improve asset classification and contextual analysis by using more intelligent discovery methods [23].

Overall, these limitations show that EWRS is useful as an integrated reconnaissance prototype, but it should be understood as a support tool for external visibility and prioritization rather than a complete vulnerability assessment platform and the limitations also show clear directions for future improvement, including more tools, better filtering, stronger timeout handling, larger scale testing and broader organizational evaluation.

7.5 Ethical and Scope Discussion

EWRS is designed for external reconnaissance and should only be used in authorized and controlled contexts and the external reconnaissance can be useful for defenders because it helps identify publicly visible assets, exposed services and possible areas that require further review. However the same techniques can also be misused if they are applied without permission and therefore the ethical scope of EWRS is an important part of this thesis.

The current EWRS prototype focuses only on publicly observable metadata and externally visible technical indicators and this includes information such as domain names, subdomains, DNS resolution results, HTTP/HTTPS response information, page titles, IP addresses, open ports, and service names and these are used to improve visibility of the external attack surface and to support prioritization.

EWRS does not access private server contents, credentials, mailboxes, databases, internal files, or restricted systems and for example when EWRS reports mail records, mail related hostnames, or mail related ports it only reports externally visible metadata and it does not open or read any mailbox content and similarly when EWRS reports IP addresses or open ports it only identifies externally visible network information and does not exploit the service.

The exposure score used by EWRS should also be understood within this ethical scope and the score does not prove that a system is vulnerable or compromised and it only indicates that an asset has externally visible indicators that may require further manual review and this distinction is important because formal vulnerability scoring systems such as CVSS are designed for known vulnerabilities and while EWRS uses reconnaissance evidence only for exposure prioritization [20].

The use of active scanning also requires care and modules such as HTTP probing and Nmap scanning interact with external systems so they should only be used against domains and systems where the user has permission to perform such checks and the scan scope should be clearly defined before running EWRS and unnecessary aggressive scanning should be avoided.

Overall, the EWRS should be used as a defensive visibility and prioritization tool and its purpose is to help security practitioners understand what is publicly visible from outside not to exploit systems or access private information and this ethical boundary is important for keeping the framework aligned with responsible security testing and authorized reconnaissance.

7.6 Future Improvements

The current EWRS prototype shows that passive and active reconnaissance can be combined into one structured workflow and however the future versions can be improved to make the framework stronger and more useful in practical security assessments.

First the EWRS could include more data sources, such as Certificate Transparency logs, WHOIS data, passive DNS datasets and other OSINT sources and certificate transparency logs are useful because they can reveal DNS names from certificates and support subdomain discovery, although they may also create information leakage concerns [21].

Second the more tools could be added to improve validation and analysis for example the future versions could include MassDNS for faster DNS resolution, Nuclei for template based vulnerability checks, technology detection tools, TLS/certificate analysis, directory enumeration, screenshot capture and web crawling and the previous work also shows that discovered subdomains become more useful when they are validated through DNS resolution or active checks[22] .

Third the EWRS could improve asset classification and filtering and future versions could classify assets as main website, API, mail server, admin panel, development server, staging server, database service, or third party infrastructure and automated OSINT research supports the value of richer public data sources and better classification for improving digital asset visibility[19].

Fourth the EWRS could add database storage and continuous monitoring and this would allow users to save scan results, compare previous and current scans, identify changes in discovered assets and run scheduled reconnaissance activities and the previous research shows that modern information systems are dynamic and that asset inventories need continuous updating because changes in system objects and network topology can affect the cybersecurity situation [39]. Therefore continuous monitoring could help EWRS maintain a more up-to-date to view of the external attack surface over time and also the recent research demonstrates the value of automated asset scanning for continuously identifying new or modified assets and maintaining a dynamic view of the IT environment [40].

The reporting function could also be improved with PDF export, charts, severity graphs, scan timelines, asset relationship diagrams and a graphical workflow view and a simple visual flowchart inside the GUI would make the EWRS easier to understand, especially for students, junior analysts and non coding users.

Overall the future work should focus on adding more data sources, more tools, better filtering, database storage, continuous monitoring, improved reports and larger scale evaluation.

7.7 Summary

This chapter discussed the main findings, contributions, limitations, ethical scope and future improvements of EWRS and the discussion showed that EWRS addresses the problem of fragmented reconnaissance by combining passive discovery, active validation, HTTP probing, port scanning, exposure scoring and reporting in one structured workflow.

The chapter also explained the contribution of the thesis to knowledge and practice and the main contribution is not the creation of a completely new reconnaissance tool but the design and evaluation of an integrated workflow that connects existing tools and makes their outputs easier to validate, organize, prioritize and report.

The limitations showed that EWRS is still a research prototype and it depends on external tools passive sources may vary, execution time can be affected by some modules and the current exposure score is only for prioritization, not vulnerability confirmation and the ethical discussion also clarified that EWRS uses publicly observable metadata only and should be used only in authorized contexts.

Finally the future improvements were identified, including adding more tools and data sources, improving filtering, adding database storage, supporting continuous monitoring, improving visual reporting and testing the framework on more domain and overall the EWRS provides a useful foundation for improving external web reconnaissance and external attack surface visibility through automation and structured reporting.

Chapter 8

Conclusion

This thesis focused on improving external web reconnaissance by reducing the fragmentation that occurs when different reconnaissance tools are used separately.The External reconnaissance normally requires different activities such as subdomain discovery, DNS validation, HTTP probing, port scanning, result processing and reporting so when these activities are performed using separate tools, the user must manually execute different commands, combine the outputs, remove duplicate results and prepare the final findings and to address this problem this thesis designed, implemented and evaluated the External Web Reconnaissance System (EWRS).

The study followed a Design Science Research approach and the EWRS framework was designed as the proposed solution while a software prototype was developed to implement and evaluate the framework. The prototype combines passive and active reconnaissance activities in one structured workflow. It integrates Subfinder and Amass for discovery, DNS validation, httpx for HTTP/HTTPS probing and Nmap for port and service discovery and also its performs result processing, duplicate removal, exposure analysis and structured reporting. The prototype provides Passive, Active and Hybrid scan modes so that different reconnaissance activities can be performed depending on the purpose of the scan.

The evaluation showed that the three scan modes support different parts of reconnaissance process first Passive Mode so the passive mode is useful for discovering candidate assets, but passive results alone cannot confirm whether the discovered assets are still active and then Active Mode supports validation by checking DNS resolution and live web services and the last but not least the Hybrid Mode so the hybrid mode provides the most complete workflow because it combines passive discovery with active validation, port scanning, exposure analysis and reporting. The evaluation therefore showed that combining passive and active

reconnaissance provides more useful external asset information than relying only on passive discovery.

The manual tool comparison also showed the main benefit of EWRS and the tools such as Subfinder, Amass, httpx and Nmap are useful individually and EWRS does not replace their technical capabilities. Instead the EWRS connects their outputs within one workflow. For example, in the KUST evaluation, the EWRS combined Subfinder, Amass and fallback candidates into 49 unique candidate assets. It then identified 25 DNS resolved assets, 25 live web services, 16 open ports and two High exposure IP addresses so the important result is not only the number of discovered assets but that EWRS was able to continue from discovery to validation, organization, exposure analysis and reporting without requiring the user to manually combine every tool output.

Based on the evaluation the main research question can be answered by stating that an automated framework combining passive and active reconnaissance can improve external attack surface visibility by connecting separate reconnaissance activities into one structured process. EWRS reduces the need for manual result handling, removes duplicate results, separates candidate assets from validated assets, identifies live web services and exposed services and presents the results in a clearer format. The findings also showed that combining different discovery sources can provide broader candidate information while active validation makes the discovered information more useful for further security review.

The main contribution of this thesis is therefore the design of the EWRS framework and the development and evaluation of its software prototype and the contribution is not the creation of completely new reconnaissance tools. Instead the contribution is the integration of existing reconnaissance techniques and tools with additional result processing, validation, exposure prioritization and reporting. The exposure scoring model also provides a simple way to prioritize externally visible assets based on observable evidence. However, the score should not be treated as proof that an asset contains a vulnerability.

EWRS also has limitations. The prototype depends on external tools and their available data sources and some modules such as Amass and Nmap can increase execution time so the Passive results can vary between scans and the current prototype has been evaluated on a limited number of target domains.The EWRS also does not perform vulnerability exploitation or confirm specific vulnerabilities and it should therefore be considered a reconnaissance and external visibility support tool rather than a complete vulnerability assessment platform.

Future development could improve EWRS by adding more passive data sources and reconnaissance tools, improving filtering and asset classification, supporting database storage and historical comparison, improving scalability and timeout handling and adding continuous

monitoring and improved graphical reporting and these improvements could make the framework more suitable for larger and more practical security environments.

Overall, the study shows that integrating passive discovery, active validation, result processing, exposure analysis and reporting into one automated workflow can make external web reconnaissance more organized and easier to manage and The EWRS provides a practical foundation for improving external attack surface visibility while keeping the existing reconnaissance tools as important components of the overall workflow.

References:

1. Kishore, B., Nivvetha, B. A., Prarthana, S., Rithish, K., & Thamaraimanalan, T. (2025, November). Enhanced Cybersecurity for Web Applications Using External Attack Surface Management. In *International Conference on Computer Science and Communication Engineering (ICCSCE 2025)* (pp. 2245-2256). Atlantis Press.
2. Rossi, M. C. (2023). Enhancing cyber assets visibility for effective attack surface management.
3. Roy, S., Sharmin, N., Acosta, J. C., Kiekintveld, C., & Laszka, A. (2022). Survey and taxonomy of adversarial reconnaissance techniques. *ACM Computing Surveys*, *55*(6), 1-38.
4. Roberts, R., & Levin, D. (2019, November). When certificate transparency is too transparent: Analyzing information leakage in https domain names. In *Proceedings of the 18th ACM Workshop on Privacy in the Electronic Society* (pp. 87-92).
5. Scheitle, Q., Gasser, O., Nolte, T., Amann, J., Brent, L., Carle, G., ... & Wählisch, M. (2018, October). The rise of certificate transparency and its implications on the internet ecosystem. In *Proceedings of the Internet Measurement Conference 2018* (pp. 343-349).
6. Kountouras, A., Kintis, P., Lever, C., Chen, Y., Nadji, Y., Dagon, D., ... & Joffe, R. (2016, September). Enabling network security through active DNS datasets. In *International Symposium on Research in Attacks, Intrusions, and Defenses* (pp. 188-208). Cham: Springer International Publishing.
7. ProjectDiscovery. (n.d.). *httpx overview*. ProjectDiscovery Documentation. Retrieved April 1, 2026, from https://docs.projectdiscovery.io/opensource/httpx/overview
8. ProjectDiscovery. (n.d.). *Subfinder overview*. ProjectDiscovery Documentation. Retrieved April 1, 2026, from https://docs.projectdiscovery.io/opensource/subfinder/overview
9. Degani, L., Bergadano, F., Mirheidari, S. A., Martinelli, F., & Crispo, B. (2022, April). Generative adversarial networks for subdomain enumeration. In *Proceedings of the 37th ACM/SIGAPP Symposium on Applied Computing* (pp. 1636-1645).
10. OWASP. (n.d.). *Amass*. OWASP Developer Guide. Retrieved April 2, 2026, from https://devguide.owasp.org/en/06-verification/02-tools/02-amass/
11. Thorsell, G. (2022). DNS Enumeration Techniques and Characterizing DNS vulnerabilities.
12. Nmap Project. (n.d.). *Nmap documentation*. Retrieved April 2, 2026, from https://nmap.org/docs.html
13. Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research1. *MIS quarterly*, *28*(1), 75-106. .
14. Peffers, K., Tuunanen, T., Gengler, C. E., Rossi, M., Hui, W., Virtanen, V., & Bragge, J. (2006, February). The design science research process: A model for producing and presenting information systems research. In *Proceedings of the First International*

Conference on Design Science Research in Information Systems and Technology (DESRIST 2006), Claremont, CA, USA (pp. 83-106).

15. FIRST. (n.d.). *Common Vulnerability Scoring System v3.0: Specification Document*. Forum of Incident Response and Security Teams. Retrieved April 3, 2026, from https://www.first.org/cvss/v3.0/specification-document
16. Python Software Foundation. (n.d.). *subprocess — Subprocess management*. Python Documentation. Retrieved May 29, 2026, from https://docs.python.org/3/library/subprocess.html
17. Schimansky, T. (n.d.). *CustomTkinter documentation*. Retrieved April 15, 2026, from https://customtkinter.tomschimansky.com/documentation/
18. Gadekar, M. R. (2024). *Consolidating reconnaissance tools and techniques for penetration testing under a single platform* (Doctoral dissertation, Dublin, National College of Ireland).
19. Babenko, T., Kolesnikova, K., Abramkina, O., & Vitulyova, Y. (2025). Automated OSINT Techniques for Digital Asset Discovery and Cyber Risk Assessment. *Computers*, *14*(10), 430.
20. Franklin, J., Wergin, C., & Booth, H. (2014). CVSS implementation guidance. *National Institute of Standards and Technology, NISTIR-7946*.
21. Scheitle, Q., Gasser, O., Nolte, T., Amann, J., Brent, L., Carle, G., ... & Wählisch, M. (2018, October). The rise of certificate transparency and its implications on the internet ecosystem. In *Proceedings of the Internet Measurement Conference 2018* (pp. 343-349).
22. Uddin, R., & Jain, A. (2025, November). An Information Scraping Framework to Prevent Future attacks. In *2nd International Conference on Sustainable Business Practices and Innovative Models (ICSBPIM-2025)* (pp. 1238-1246). Atlantis Press.
23. Coppolino, L., Iannaccone, A., Nardone, R., & Petruolo, A. (2025). Asset Discovery in Critical Infrastructures: An LLM-Based Approach. *Electronics*, *14*(16), 3267.
24. Patil, S., & Borisov, N. (2019, July). What can you learn from an IP?. In *Proceedings of the 2019 Applied Networking Research Workshop* (pp. 45-51).
25. Roberts, R., & Levin, D. (2019, November). When certificate transparency is too transparent: Analyzing information leakage in https domain names. In *Proceedings of the 18th ACM Workshop on Privacy in the Electronic Society* (pp. 87-92).
26. van Rijswijk-Deij, R., Jonker, M., Sperotto, A., & Pras, A. (2016). A high-performance, scalable infrastructure for large-scale active DNS measurements. *IEEE journal on selected areas in communications*, *34*(6), 1877-1888.
27. Microsoft. (2026). *What is PowerShell?* Microsoft Learn. Retrieved June 7, 2026, from https://learn.microsoft.com/en-us/powershell/scripting/overview?view=powershell-7.6
28. Biškupić, I. O., Balković, M., & Bencarić, I. (2026). An Evidence-Based Architecture for Trustworthy Asset Discovery in Cybersecurity-Critical IT Environments. *Journal of cybersecurity and privacy*, *6*(2), 67.

29. Ismail, Kurnia, R., Brata, Z. A., Nelistiani, G. A., Heo, S., Kim, H., & Kim, H. (2025). Toward robust security orchestration and automated response in security operations centers with a hyper-automation approach using agentic artificial intelligence. *Information*, *16*(5), 365.
30. Sinan, M., Shahin, M., & Gondal, I. (2025). Integrating security controls in DevSecOps: Challenges, solutions, and future research directions. *Journal of Software: Evolution and Process*, *37*(6), e70029.
31. Staves, A., Gouglidis, A., & Hutchison, D. (2023). An analysis of adversary-centric security testing within information and operational technology environments. *Digital Threats: Research and Practice*, *4*(1), 1-29.
32. Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). Technical guide to information security testing and assessment. *NIST Special Publication*, *800*(115), 2-25.
33. Edwards, B., Jacobs, J., & Forrest, S. (2019). Risky business: Assessing security with external measurements. *arXiv preprint arXiv:1904.11052*.
34. Mell, P., Scarfone, K., & Romanosky, S. (2006). Common vulnerability scoring system. *IEEE Security & Privacy*, *4*(6), 85-89.
35. Islam, C., Babar, M. A., & Nepal, S. (2019). A multi-vocal review of security orchestration. *ACM Computing Surveys (CSUR)*, *52*(2), 1-45.
36. Baiardi, F., & Sammartino, V. (2026). Simulation-powered cybersecurity: Real-time risk assessment via non-intrusive security twin. *The Journal of Supercomputing*, *82*(5), 311.
37. Alrowaili, Y., Saxena, N., Srivastava, A., Conti, M., & Burnap, P. (2023). A review: Monitoring situational awareness of smart grid cyber‐physical systems and critical asset identification. *IET Cyber‐Physical Systems: Theory & Applications*, *8*(3), 160-185.
38. Boyanov, P. (2025). A COMPREHENSIVE METHODOLOGY FOR NETWORK ASSET IDENTIFICATION AND MAPPING: A COMPREHENSIVE METHODOLOGY FOR NETWORK ASSET IDENTIFICATION AND MAPPING. *Journal scientific and applied research*, *29*(1), 158-176.
39. Kotenko, I., Doynikova, E., Fedorchenko, A., & Desnitsky, V. (2022). Automation of asset inventory for cyber security: investigation of event correlation-based technique. *Electronics*, *11*(15), 2368.
40. Calvo‐Manzano, J. A., San Feliu, T., Herranz, Á., Mariño, J., Fredlund, L. Å., & Moreno, A. M. (2025). CyberESP: An integrated cybersecurity framework for SMEs. *Journal of Software: Evolution and Process*, *37*(9), e70050.